

UE04 · PRODUIT ET STORYTELLING

WellWork

Audit RGPD et sécurité

Dossier de remédiation et pilotage agile

Christopher De Pasqual
1er octobre 2026

Le résultat en bref

Les accès aux profils et questionnaires sont restreints, les sessions et mots de passe renforcés, et l'export assureur suspendu. Le plan de remédiation traite les points encore ouverts : usages des données de santé, habilitations, conservation et sauvegardes.

Parties A–D : **30** pages, couverture et sommaire compris.

Annexes : **19** pages, identifiées séparément.

La présentation E est un livrable distinct.

[Code, historique des corrections et preuves](#)

Sommaire

Les liens conduisent aux sections du dossier. Le code et les sources officielles sont accessibles en ligne.

A.1 — Registre des traitements	3
A.2 — Bases légales et acteurs	5
A.3 — Analyse d'impact	9
A.4 — Non-conformités RGPD	11
B.1 — Constats de sécurité	13
B.2 — Scénarios de fuite	15
B.3 — Violation et notifications	17
C.1 — Plan de remédiation	19
C.2 — Correctifs et preuves	20
C.3 — Risques résiduels	23
D — Pilotage agile	25

Annexes

Annexe 1 — Transparence IA	31
Annexe 2 — Backlog détaillé	34
Annexe 3 — Données de planification	39
Annexe 4 — Sources et contrôles de D	42
Annexe 5 — Preuves initiales	44
Annexe 6 — Fiabilisation et recettes	47

A–B : constats sur la version initiale. C : corrections et risques restants. D : plan de remédiation proposé.

Partie A.1 — Cartographie initiale des traitements WellWork

- **Version** : 1.3 — 1er octobre 2026
- **Référence technique** : baseline-vulnérable, commit e16cedcf0f8adb359621240366c8f0cbb251b8c9
- **Périmètre** : application WellWork, données et flux décrits dans l'énoncé et observables dans le support fourni

Cette cartographie est structurée selon l'article 30 du RGPD. Elle recense les finalités, personnes, données, destinataires, transferts, durées et protections connus, mais ne constitue pas encore le registre organisationnel définitif. [A.2](#) analyse les rôles sous hypothèses explicites, faute de contrats. Les activités réalisées comme responsable de traitement et celles réalisées comme sous-traitant devront être distinguées dans les registres appropriés après validation de ces rôles.

La CNIL recommande d'identifier les traitements par finalité et non par logiciel. Les affirmations ci-dessous distinguent donc les activités annoncées dans l'énoncé, les faits observés dans le code et les informations restant à confirmer.

Informations générales disponibles et manquantes

Élément	État
Organisme	« WellWork » est le nom utilisé par le support; raison sociale, adresse et coordonnées à fournir
Responsable, responsables conjoints ou clients responsables	Hypothèses en A.2, à valider à partir des décisions réelles et des contrats
Représentant dans l'UE et DPO	Existence et coordonnées non documentées
Sous-traitants techniques et hébergeur	Non documentés
Responsable de la tenue du registre	À désigner

Les antécédents et traitements médicaux sont des données de santé par nature. Le stress, le poids, la taille, le sommeil ou le tabagisme peuvent aussi révéler la santé par leur croisement, leur contexte ou l'usage qui en est fait; une mesure isolée ne doit toutefois pas être automatiquement qualifiée comme telle.

Fiches de traitement

RT-01 — Comptes et authentification

- **Finalités** : créer et administrer les comptes, authentifier les utilisateurs, gérer les sessions, le profil et la demande de suppression.
- **Personnes et données** : salariés, RH, coachs et administrateurs; identité, email, entreprise, date de naissance, rôle, statut du compte, dates de création/suppression, mot de passe saisi puis empreinte conservée, jeton et date de session, `marketingOptIn`.
- **Destinataires** : utilisateur concerné et administrateurs habilités — périmètre à confirmer. En pratique, RT-04 expose des profils à tout compte authentifié et RT-05 les expose aux RH et administrateurs.
- **Transferts et conservation** : aucun transfert hors UE démontré. Aucune durée ni purge applicative observée; procédures externes non documentées. `DELETE /api/me` conserve le compte et ses données liées. Les durées cibles doivent distinguer compte actif, compte fermé, session et éventuel archivage justifié.
- **Protections observées** : authentification Bearer et empreinte SHA-256. Le navigateur stocke le jeton dans `localStorage`; il s'agit d'une modalité de stockage, pas d'un destinataire. Limites détaillées dans SEC-02, SEC-03, SEC-05, PRIV-05 et PRIV-06.
- **Références** : `src/routes/accounts.js:11-64`, `src/auth.js:7-38`, `public/index.html:41-57`.

RT-02 — Questionnaires de santé et de bien-être

- **Finalités** : recueillir les réponses nécessaires au service de bien-être et les restituer avec le profil; l'usage exact pour le coaching, la prévention ou l'assurance reste à confirmer.
- **Personnes et données** : salariés; identifiant, date, poids, taille, sommeil, stress, antécédents, traitement médical, tabagisme et réponses libres acceptées par l'API. Les antécédents et traitements sont des données de santé; les autres mesures peuvent le devenir selon leur croisement et leur contexte.
- **Destinataires** : salarié concerné; coachs ou professionnels dont l'habilitation reste à définir; assureur annoncé pour RT-05. Le code permet actuellement à tout compte authentifié de consulter les questionnaires d'un tiers et aux RH/administrateurs de tous les exporter.

- **Transferts et conservation** : aucun transfert externe démontré. Aucune durée ni purge applicative observée; les questionnaires subsistent après DELETE /api/me. La politique cible doit être définie selon chaque finalité validée, les éventuelles obligations sectorielles et les besoins d'archivage justifiés.
- **Protections observées** : authentification préalable, mais pas de contrôle de propriété, de rôle ou d'entreprise. Voir PRIV-01, PRIV-03, PRIV-04 et PRIV-05.
- **Références** : src/routes/data.js:10-27, 47-55, db/seed.js:52-67.

RT-03 — Messagerie coach-salarié

- **Finalités** : permettre les échanges liés à l'accompagnement.
- **Personnes et données** : salariés et coaches; identifiants de l'expéditeur et du destinataire, contenu libre, date. Le texte peut contenir des informations personnelles ou de santé selon ce que l'utilisateur écrit.
- **Destinataires** : expéditeur et destinataire; éventuels accès support à confirmer. La lecture est filtrée sur from/to, mais tout compte authentifié peut envoyer un message sans contrôle d'une relation de coaching.
- **Transferts et conservation** : aucune messagerie externe démontrée. Aucune durée, purge ou procédure externe documentée. La durée cible doit tenir compte de la période d'accompagnement et d'un éventuel archivage contentieux justifié.
- **Protections observées** : authentification et filtrage des messages à la lecture; limites d'habilitation non couvertes par un constat dédié.
- **Références** : src/routes/data.js:37-45, src/db.js:13.

RT-04 — Tableau de bord RH annoncé, annuaire et consultation des profils

- **Finalités** : fournir aux coaches et aux RH un annuaire et les profils utiles à leurs missions. L'énoncé annonce aussi un « tableau de bord RH ».
- **Correspondance énoncé/code** : dans le code observé, les seules fonctions susceptibles d'alimenter ce tableau de bord sont la liste des utilisateurs et la consultation des profils. Aucune vue dédiée, statistique, agrégation ou indicateur RH n'est implémenté. RT-04 recense donc l'activité annoncée sans lui attribuer de données ni d'usages supplémentaires; toute future fonction de pilotage devra être ajoutée au registre selon son contenu réel.
- **Personnes et données** : titulaires de comptes; identité, email, entreprise, date de naissance, rôle, statut et empreinte du mot de passe; la fiche détaillée joint les questionnaires.
- **Destinataires** : destinataires métier annoncés : coaches et RH. Leurs habilitations par entreprise ou portefeuille sont des hypothèses à valider. Accès observé : tout compte authentifié, sans restriction de rôle ni de tenant.
- **Transferts et conservation** : aucun transfert démontré. La conservation suit celle des données sources RT-01 et RT-02; aucune purge applicative n'est observée.
- **Protections observées** : authentification seulement. Les accès excessifs et le filtre JavaScript sont documentés dans SEC-01, PRIV-01, PRIV-02, PRIV-03 et PRIV-06.
- **Références** : src/routes/data.js:22-35, src/db.js:30-37.

RT-05 — Export annoncé pour l'assureur

- **Finalités** : constituer un export annoncé comme destiné à un assureur; l'objectif métier précis et la nécessité des données restent inconnus.
- **Personnes et données** : tous les utilisateurs présents en base. Les **données sources** sont les comptes et questionnaires. La **réponse HTTP** contient leurs propriétés complètes, dont passwordHash, et les questionnaires. La collection exports ne conserve pas une copie de l'export : elle enregistre seulement id, auteur, date et nombre de lignes. Le journal conserve également des métadonnées.
- **Destinataires** : assureur annoncé mais non identifié; administrateurs et RH peuvent obtenir la réponse. Après SEC-02, un salarié peut aussi y accéder. Le code ne prouve aucun envoi effectif à l'assureur.
- **Transferts et conservation** : pays et canal du destinataire inconnus; aucun transfert hors UE ne peut être conclu. Aucune purge applicative des données sources ou des traces exports n'est observée. La conservation éventuelle de la réponse chez le destinataire est inconnue.
- **Protections observées** : authentification et contrôle de rôle acceptant admin et rh; limites dans SEC-02, PRIV-04 et PRIV-06.
- **Références** : src/auth.js:31-38, src/routes/data.js:47-55.

RT-06 — Préférences marketing et partage à des tiers

- **Finalités** : enregistrer des indicateurs marketing et de partage à des tiers; aucune campagne ni transmission n'est observable dans le support.
- **Personnes et données** : utilisateurs inscrits; marketingOptIn dans le profil, et enregistrements séparés consents contenant identifiant, marketing, thirdParty et date.
- **Destinataires** : équipe marketing et tiers éventuels, non identifiés. marketingOptIn apparaît dans les réponses de profil; les enregistrements consents n'ont pas de route dédiée.

- **Fonctionnement constaté** : à l'inscription, les trois indicateurs sont imposés à true; ils ne prouvent donc pas un choix exprimé. PATCH /api/me peut modifier marketingOptIn, mais ne synchronise pas la collection consents. Il n'existe pas de procédure cohérente de retrait ou d'historisation.
- **Transferts et conservation** : aucun transfert démontré. Aucune durée ni purge applicative observée; procédures externes non documentées. Les durées cibles devront distinguer usage des préférences et conservation justifiée d'une preuve de choix ou de retrait.
- **Protections et preuves** : horodatage des consents, mais cohérence non garantie. Voir PRIV-07; src/routes/accounts.js:20-32,48-58, db/seed.js:27-32.

RT-07 — Journalisation technique et support

- **Finalités** : diagnostic, support et traçabilité des inscriptions, connexions, modifications de profil et exports.
- **Personnes et données** : utilisateurs et opérateurs, mais aussi personnes tentant une inscription ou une connexion sans disposer d'un compte; date, événement, email, entreprise, mot de passe saisi en clair, identifiant, champs modifiés, auteur et volume d'export.
- **Destinataires** : personnes ou processus ayant accès au fichier de log ou à stdout; équipes techniques/support et prestataires éventuels à identifier.
- **Transferts et conservation** : aucun service externe de logs démontré. Écriture en ajout continu, sans durée, rotation ou purge applicative observée; procédures externes non documentées.
- **Protections observées** : stdout peut être désactivé. Le stockage en fichier et son chemin configurable ne constituent pas à eux seuls des protections; habilitations et chiffrement ne sont pas documentés. Voir SEC-04.
- **Références** : src/logger.js:6-14, src/routes/accounts.js:15,39, src/routes/data.js:53-54.

RT-08 — Suivi des séances sportives

- **État** : activité décrite dans l'énoncé, non observable dans le support technique; une collection vide sessionsSport existe, sans route ni donnée associée.
- **Personnes concernées** : salariés, selon l'énoncé.
- **À confirmer** : finalité précise, données, destinataires, transferts, durées, stockage et protections. Aucun de ces éléments ne peut être déduit de manière fiable du code fourni.
- **Références** : énoncé, page 1; src/db.js:13.

Notes communes et validations nécessaires

L'hébergement, les sauvegardes, les prestataires, leurs pays, les accès de support et les contrats ne sont pas documentés. L'absence de flux sortant dans le code ne prouve donc pas l'absence de transfert international. Il faut identifier ces acteurs, puis documenter pays, garanties et sous-traitants ultérieurs.

Pour les activités observables dans le code, la preuve technique est la même : **aucune durée ni purge applicative observée; procédures externes non documentées**. La politique cible devra distinguer base active, éventuel archivage intermédiaire et suppression. Les critères à examiner sont la finalité, la fin de la relation, les obligations sectorielles applicables, les délais de recours et la nécessité de chaque donnée. Aucune durée légale n'est déduite ou inventée ici.

Restent à valider : identité et coordonnées des acteurs et du DPO; qualification juridique en A.2; finalités métier exactes; habilitations prévues; hébergement et transferts; sous-traitants; durées et modalités d'effacement; mesures organisationnelles; réalité et modalités des activités assureur, marketing et sport.

Références officielles

- [RGPD, article 30 — registre des activités de traitement](#)
- [CNIL — Le registre des activités de traitement](#)
- [CNIL — Les durées de conservation des données](#)
- [CNIL — Qu'est-ce qu'une donnée de santé ?](#)

Partie A.2 — Bases légales et qualification des acteurs

- **Version** : 1.2 — 1er octobre 2026
- **Référence technique** : baseline-vulnérable, commit e16cedcf0f8adb359621240366c8f0cbb251b8c9
- **Périmètre** : traitements RT-01 à RT-08 définis en A.1

1. Hypothèse de travail

Faute de contrats et d'information aux salariés dans le support, l'hypothèse principale est conditionnelle : les clients déterminent les objectifs de leur programme et WellWork fournit la plateforme. Le client serait responsable des traitements du programme, WellWork sous-traitant quand elle agit sur instruction. Une finalité autonome décidée par WellWork avec ses moyens essentiels, ou une codétermination avec le client, modifierait ce rôle. Choisir les outils ou les détails techniques de sécurité ne suffit pas à devenir responsable de traitement.

Le rôle réel prévaut sur l'étiquette contractuelle : le responsable décide des finalités et moyens essentiels; le sous-traitant agit pour son compte sur instruction. Des décisions communes ou complémentaires et indissociables peuvent conduire à la responsabilité conjointe ([CNIL, CEPD, lignes directrices 07/2020](#)).

Chaque traitement exige une base de l'article 6. Le contrat suppose que la personne soit partie et le traitement objectivement nécessaire : le contrat B2B avec l'employeur ne suffit pas pour le salarié ([CNIL — contrat](#)). L'intérêt légitime exige un intérêt réel, la nécessité et une mise en balance documentée avec les droits et attentes raisonnables ([CNIL — intérêt légitime](#)). Les données de santé exigent aussi une exception de l'article 9; ni contrat ni intérêt légitime ne lèvent seuls l'interdiction ([RGPD, articles 6 et 9](#)).

2. Analyse par traitement

RT-01 — Comptes et authentification

Finalité. Créer et administrer les comptes, authentifier les utilisateurs et gérer leurs sessions.

Hypothèse d'acteur. L'entreprise cliente serait responsable si elle décide quels comptes professionnels ouvrir et quels accès fournir, WellWork exécutant alors cette partie comme sous-traitant. WellWork serait responsable séparé des traitements de session ou de sécurité dont elle fixe elle-même la finalité.

Base privilégiée. L'article 6(1)(f), intérêt légitime à fournir et sécuriser l'accès, est envisageable pour les seules données nécessaires. Il faut documenter l'intérêt, l'absence de moyen moins intrusif et la mise en balance. L'article 6(1)(b) serait applicable si un contrat de service lie directement le salarié à WellWork et rend le compte objectivement nécessaire; il n'existe pas de préférence automatique entre ces bases.

Conclusion. Le cœur compte/authentification est justifiable sous conditions, mais le support ne démontre ni contrat direct ni mise en balance. La nécessité de la date de naissance n'est pas établie. Aucune base ne justifie l'exposition de passwordHash, l'élévation de rôle ou les sessions sans expiration.

RT-02 — Questionnaires de santé et de bien-être

Finalité. Recueillir et utiliser les réponses nécessaires au service de bien-être; les usages de coaching, prévention ou assurance restent à définir.

Hypothèse d'acteur. L'entreprise cliente serait responsable si elle fixe l'objectif du questionnaire et les destinataires, WellWork étant sous-traitant. Si WellWork définit avec elle les questions, usages ou exports, une responsabilité conjointe doit être examinée.

Base privilégiée. Pour un service réellement facultatif, l'hypothèse la plus cohérente est le consentement au titre de l'article 6(1)(a), accompagné du consentement **explicite** de l'article 9(2)(a). Il doit être spécifique par finalité, éclairé, prouvable, retirable et libre : refus sans conséquence professionnelle ou perte d'un service essentiel. Dans la relation de travail, le déséquilibre exige une vigilance renforcée, sans rendre le consentement toujours impossible ([CNIL, CEPD 05/2020](#)).

Conclusion. La licéité n'est pas établie dans le support : aucun consentement santé n'y est recueilli et les indicateurs imposés ne constituent pas un choix. L'article 9(2)(h) exige une finalité admissible (notamment médecine préventive ou du travail, soins), le fondement qu'il prévoit et les garanties de secret de l'article 9(3); un coach bien-être n'est pas automatiquement un professionnel de santé.

RT-03 — Messagerie coach-salarié

Finalité. Permettre les échanges liés à l'accompagnement.

Hypothèse d'acteur. L'entreprise cliente serait responsable de l'accompagnement qu'elle organise; WellWork serait sous-traitant si la messagerie répond à ses instructions. WellWork pourrait être responsable si elle organise elle-même le coaching.

Base privilégiée. L'article 6(1)(f) peut couvrir une messagerie limitée et attendue, après test de nécessité et mise en balance. L'article 6(1)(b) ne s'applique que si la personne a un contrat direct rendant la messagerie nécessaire. Dès que des données de santé y sont traitées, y compris par leur stockage dans un message libre, une exception de l'article 9 est également requise; elle n'est pas démontrée. L'absence d'exploitation médicale ne dispense pas de cette analyse.

Conclusion. La messagerie ordinaire est justifiable sous conditions. Le contenu de santé et l'envoi à tout identifiant exigent un cadrage supplémentaire.

RT-04 — Tableau de bord RH annoncé, annuaire et consultation des profils

Finalité. Fournir l'annuaire et les profils nécessaires aux missions autorisées des coaches et RH. L'énoncé annonce un tableau de bord RH, mais le code ne démontre que la liste et la consultation de profils : aucune statistique ou agrégation ne peut être présumée.

Hypothèse d'acteur. L'entreprise cliente serait responsable de son annuaire RH; ses RH sont normalement des personnes habilitées sous son autorité, non un responsable distinct. WellWork serait sous-traitant si elle exécute ce périmètre.

Base privilégiée. L'article 6(1)(f) peut être envisagé pour un annuaire professionnel minimal, limité à l'entreprise et aux personnes dont les missions exigent l'accès. La nécessité, les champs et les attentes des salariés doivent être documentés. Cette analyse ne couvre pas automatiquement un futur tableau de bord : ses indicateurs, niveau d'agrégation, destinataires et nécessité devront être évalués; s'ils révèlent la santé, une exception de l'article 9 sera aussi requise.

Conclusion. Un annuaire restreint peut être justifié, mais pas l'implémentation actuelle : accès de tout compte, données multi-entreprises, hash et questionnaires. La licéité du tableau de bord annoncé reste indéterminée tant que son fonctionnement n'est pas décrit; l'intérêt légitime ne couvre ni ces excès ni les données de santé sans exception de l'article 9.

RT-05 — Export annoncé pour l'assureur

Finalité. Constituer un export annoncé comme destiné à l'assureur; son objectif métier précis n'est pas documenté.

Hypothèse d'acteur. L'acteur qui décide l'objectif et le contenu de l'export est responsable. Si l'assureur reçoit les données pour ses propres décisions, il est vraisemblablement responsable autonome, pas sous-traitant du seul fait qu'il est destinataire. Une décision commune client–WellWork–assureur pourrait modifier cette qualification.

Base envisageable. Aucun fondement n'est démontré. Un consentement explicite articles 6(1)(a) et 9(2)(a) serait théoriquement possible, mais seulement avec finalité précise, choix séparé, absence de conséquence et retrait effectif. Aucune obligation légale d'export ne peut être supposée. Le contrat B2B et l'intérêt légitime ne suffisent pas pour les données de santé.

Conclusion. La licéité de RT-05 n'est pas établie. Suspendre cet export dans la cible tant que sa finalité, les données nécessaires, le cadre article 9, les éventuelles restrictions sectorielles et le canal réel ne sont pas validés. Le code produit une réponse HTTP, sans prouver un envoi à l'assureur annoncé dans l'énoncé.

RT-06 — Préférences marketing et partage à des tiers

Finalité. Gérer les préférences et leur preuve, puis, si elles sont mises en œuvre, les campagnes marketing ou communications à des tiers.

Hypothèse d'acteur. WellWork est responsable de son propre marketing; chaque client ou tiers est responsable de ses finalités, ou conjoint si les décisions sont réellement communes.

Base privilégiée. Le consentement article 6(1)(a) est l'hypothèse de travail pour des campagnes ou transmissions à des tiers nécessitant un accord. Il doit être libre, spécifique par finalité, éclairé, univoque et aussi simple à retirer qu'à donner. Distinguer cette utilisation de la preuve du consentement et de la gestion d'un retrait ou d'une opposition : leur conservation minimale répond aux obligations des articles 7(1), 7(3) et 21(3), sur le fondement de l'article 6(1)(c), selon le cas. Elle n'autorise aucune nouvelle prospection. Les campagnes non observées devront être analysées selon leur canal et leurs destinataires ([articles 7 et 6](#), [article 21](#)).

Conclusion. Les valeurs forcées à true, l'absence de choix et la désynchronisation entre `marketingOptIn` et `consents` ne démontrent aucun consentement valide. La licéité d'un usage marketing ou tiers n'est donc pas établie.

RT-07 — Journalisation technique et support

Finalité. Assurer la sécurité, le diagnostic, le support et une traçabilité proportionnée du service.

Hypothèse d'acteur. WellWork reste sous-traitante pour les journaux nécessaires au service fourni sur instruction, même si elle choisit les mesures techniques de sécurité. Elle serait responsable d'une journalisation poursuivant une finalité autonome dont elle détermine les moyens essentiels. Cette distinction doit être documentée, sans qualifier automatiquement tout support technique de traitement autonome.

Base privilégiée. L'article 6(1)(f) est envisageable pour des journaux nécessaires à la sécurité, au diagnostic et à la défense du service, après définition des événements utiles, durée, accès et mise en balance. Aucune obligation légale spécifique n'est fournie.

Conclusion. Une journalisation minimisée est justifiable sous conditions; l'enregistrement des mots de passe en clair n'est ni nécessaire ni proportionné et ne peut être couvert par cette base (SEC-04).

RT-08 — Suivi sportif annoncé

Finalité. Permettre le suivi des séances sportives des salariés, selon l'énoncé; les objectifs précis restent inconnus.

Hypothèse d'acteur. Si l'entreprise cliente fixe l'objectif du suivi, elle serait responsable et WellWork sous-traitant; si WellWork en détermine les usages, son rôle autonome ou conjoint doit être examiné.

Base envisageable. L'article 6(1)(b) pourrait convenir à un service nécessaire souscrit directement par le salarié; l'intérêt légitime ou le consentement dépendraient d'un autre modèle. Si les données révèlent la santé, une exception de l'article 9 serait aussi nécessaire.

Conclusion. Le code ne démontre ni fonctionnement ni données. Base légale, exception et responsabilités restent indéterminées sans description du service et des décisions.

3. Qualification transversale des acteurs

Entreprise cliente

Qualification principale sous hypothèse : Responsable des finalités du programme salarié, de l'annuaire et des habilitations **Ce qui peut la modifier :** Responsabilité conjointe si WellWork co-détermine les finalités/moyens essentiels **Documents nécessaires :** Contrat B2B, politiques RH, information des salariés, matrice d'habilitation

WellWork

Qualification principale sous hypothèse : Sous-traitant des traitements exécutés sur instruction; responsable de ses finalités autonomes, par exemple son propre marketing **Ce qui peut la modifier :** Responsable conjoint ou autonome selon les décisions de finalité et de moyens essentiels; pas pour le seul choix d'outils techniques **Documents nécessaires :** Contrat article 28, conditions du service, documentation des décisions et instructions

RH

Qualification principale sous hypothèse : Personnes habilitées sous l'autorité du client, sauf organisme distinct **Ce qui peut la modifier :** Autonomie réelle sur les finalités et moyens **Documents nécessaires :** Fiches de rôle, délégations et procédures d'accès

Coach

Qualification principale sous hypothèse : Personne autorisée s'il est interne; sous-traitant externe s'il agit sur instruction, éventuellement sous-traitant ultérieur de WellWork **Ce qui peut la modifier :** Responsable autonome s'il détermine ses propres finalités professionnelles **Documents nécessaires :** Statut, contrat, instructions, confidentialité; qualification professionnelle éventuelle

Assureur

Qualification principale sous hypothèse : Destinataire et probablement responsable autonome s'il poursuit ses propres finalités **Ce qui peut la modifier :** Sous-traitant seulement s'il agit exclusivement sur instructions; responsabilité conjointe si décisions communes **Documents nécessaires :** Convention d'échange, finalités, catégories de données, pays, durées et information

Hébergeur/prestataire

Qualification principale sous hypothèse : Sous-traitant technique s'il est effectivement utilisé **Ce qui peut la modifier :** Responsable pour une réutilisation propre non couverte par les instructions **Documents nécessaires :** Identité, localisation, contrat article 28 et chaîne de sous-traitance

En cas de responsabilité conjointe, un accord transparent doit répartir les obligations de l'article 26. Un sous-traitant doit être encadré par l'article 28. Les RH, salariés de WellWork ou coachs internes agissant sous autorité doivent respecter les instructions conformément à l'article 29 ([RGPD, articles 26 à 29](#)).

4. Mise en balance préliminaire des intérêts légitimes

Cette analyse porte sur la cible minimisée, pas sur une régularisation des accès actuels. Elle doit être validée par le responsable réel avec les salariés concernés.

Traitement	Intérêt et nécessité envisagés	Mise en balance et conclusion
RT-01	Accès individuel au service; identifiant et authentifiant nécessaires à la séparation des comptes	Attente raisonnable de sécurité; pas de date de naissance sans justification, ni réutilisation marketing. Favorable sous ces garanties, défavorable aux excès actuels
RT-03 hors santé	Joindre le coach attribué; échange direct moins exposant qu'un espace collectif	Participation facultative, confidentialité, destinataires contrôlés, opposition examinée. Favorable sous conditions; article 9 à traiter séparément
RT-04	Administrer les seuls comptes utiles aux missions du client	Annuaire réduit plutôt que profils complets; accès salarié général et santé exclus. Favorable pour les habilités du même client, défavorable à l'annuaire actuel
RT-07	Détecter des incidents et diagnostiquer les erreurs avec événements et identifiants limités	Logs sans mots de passe ni réponses santé, accès restreint et durée motivée; alternative moins intrusive aux contenus complets. Favorable uniquement sous ces garanties

5. Conclusion opérationnelle

- **Justifiables sous conditions** : RT-01 pour les données strictement nécessaires, RT-03 hors santé, RT-04 sous forme d'annuaire minimal et cloisonné, RT-07 sans secrets. Il faut choisir et documenter la base, la nécessité et, pour l'intérêt légitime, la mise en balance.
- **Licéité non établie dans le support** : RT-02, RT-05 et les usages marketing/tiers de RT-06; RT-08 reste indéterminé. Les conditions de consentement et de l'article 9 ne sont pas démontrées.
- **Validation prioritaire** : obtenir contrats et informations salariés, cartographier les décisions réelles, identifier l'assureur/coachs/hébergeur, documenter les tests d'intérêt légitime et concevoir des consentements réellement libres lorsque cette base est retenue.

Quelle que soit la base légale, elle ne justifie jamais les accès excessifs, l'absence de minimisation ou les données inutiles constatés dans le code.

Partie A.3 — AIPD des questionnaires de santé

- **Version** : 1.1 — 1er octobre 2026
- **Référence** : baseline-vulnérable, commit e16cedcf0f8adb359621240366c8f0cbb251b8c9
- **Statut** : analyse du cas pédagogique et mesures proposées; aucune validation organisationnelle ni remédiation technique n'est présumée.

1. Obligation et périmètre retenu

L'AIPD est obligatoire pour le traitement de santé des salariés décrit dans le sujet : données sensibles et déséquilibre employeur-salarié se combinent à des accès interentreprises et à un export nominatif. Le traitement est susceptible d'engendrer un risque élevé pour les personnes, au sens de l'[article 35\(1\)](#).

Deux critères des [lignes directrices WP248 rév.01, pages 11 à 13](#) sont établis : données sensibles (antécédents, traitements médicaux) et personnes vulnérables dans la relation de travail. Le cumul est un indicateur fort, pas une règle automatique remplaçant l'analyse du contexte. Les impacts professionnels possibles et les destinataires multiples confirment ici le risque élevé.

La grande échelle, le profilage et la décision automatisée ne sont pas démontrés : les 63 comptes de démonstration ne mesurent pas la population réelle. On ne fonde donc pas la conclusion sur l'article 35(3)(b). Les [listes CNIL](#) ne permettent ni d'assimiler ce service à un établissement de soins, ni d'appliquer sans vérification l'exemption relative à certaines gestions RH courantes.

Traitement choisi : **RT-02**, depuis la collecte des réponses jusqu'à leur consultation, export et effacement. RT-01, RT-04 et RT-05 sont inclus comme dépendances : ils permettent l'identification et l'exposition des questionnaires. Ce périmètre est prioritaire car il associe identité, santé et contexte professionnel. RT-03 et RT-08 devront être réévalués si leurs usages réels révèlent de la santé.

2. Description du traitement — article 35(7)(a)

La finalité annoncée est l'accompagnement au bien-être; les usages précis de prévention et d'assurance restent à justifier. Selon l'hypothèse d'[A.2](#), le client pilote son programme et WellWork l'exécute sur instruction; les éventuelles finalités autonomes ou conjointes restent à qualifier.

Le salarié saisit ses réponses; l'API ajoute son identifiant et la date puis conserve l'ensemble dans un fichier JSON. La fiche utilisateur les restitue; l'export joint tous les questionnaires aux comptes. La suppression du compte conserve les réponses et laisse les accès fonctionner. Preuves : [routes de données](#), [stockage](#), [comptes](#) et constats PRIV-01, PRIV-03, PRIV-04, PRIV-05 de la [matrice initiale](#).

Destinataires métier à définir : salarié et accompagnants habilités; l'énoncé annonce un assureur. Accès réel : tout compte authentifié peut lire un tiers; RH et administrateurs exportent toutes les entreprises. La collection exports conserve des métadonnées, pas la réponse complète. Aucun envoi effectif à l'assureur n'est prouvé par le code. Hébergement, pays, sauvegardes, protections de l'infrastructure et volume réel restent inconnus.

3. Nécessité et proportionnalité — article 35(7)(b)

Point	Évaluation et décision proposée
Licéité	Articles 6 et 9 à satisfaire ensemble. Le consentement explicite n'est envisageable que pour un service réellement facultatif, sans désavantage au refus. Aucune preuve correspondante dans le support : ne pas ouvrir une collecte réelle en l'état
Données nécessaires	Justifier chaque question par l'accompagnement fourni; retirer les antécédents et traitements si cette nécessité n'est pas démontrée. Remplacer les réponses arbitraires de l'API par un schéma limité

Point	Évaluation et décision proposée
Destinataires	Exclure la santé individuelle de l'annuaire RH. Réserver la lecture au salarié et aux accompagnants effectivement habilités. Suspendre l'export assureur tant que sa finalité et sa licéité ne sont pas établies
Alternative moins intrusive	Pour le pilotage RH, étudier des indicateurs réellement anonymisés avec prévention des petits groupes; enlever le nom ou remplacer l'identifiant ne suffit pas à garantir l'anonymat
Information et droits	Fournir une notice avant collecte, des choix distincts, une preuve et un retrait effectifs; procédure d'accès, rectification, effacement et autres droits selon la base. Aucun droit n'est remplacé par une simple case d'acceptation
Conservation	Limiter la base active à la période d'accompagnement justifiée, puis supprimer les réponses devenues inutiles; fixer et tester le délai opérationnel. Toute archive et sauvegarde doit avoir une finalité, une durée et des accès propres. Aucun délai légal forfaitaire n'est inventé

Ces décisions appliquent les [articles 5, 6, 7 et 9](#) et les [articles 12 à 22](#). Elles restent à mettre en œuvre : une AIPD ne régularise pas une collecte illicite.

4. Risques pour les personnes — article 35(7)(c)

Échelle propre à cet audit, non imposée par la CNIL et distincte du CVSS : gravité **G**, de 1 (désagrément limité) à 4 (atteinte majeure potentiellement durable); vraisemblance **V**, de 1 (peu probable avec garanties vérifiées) à 4 (exposition facilement reproductible). G2 correspond à un préjudice réversible, G3 à un préjudice sérieux; V2 à un scénario plausible non vérifié, V3 à un scénario facilité mais demandant des conditions supplémentaires. Score $G \times V$: 1–3 faible, 4–7 modéré, 8–11 élevé, 12–16 critique. La qualification juridique de risque élevé ne dépend pas uniquement du score.

Risque, source et scénario	Conséquence humaine possible	Évaluation initiale motivée
R1 — Divulgaration : salarié, compte compromis ou RH lisant/exportant hors habilitation (PRIV-01/03/04, SEC-02/03)	Stigmatisation, chantage, discrimination professionnelle; diffusion difficile à réparer	$G4 \times V4 = 16$, critique : accès excessifs reproduits, sans preuve d'une fuite réelle par ce chemin
R2 — Altération : attaquant authentifié utilisant l'évaluation JavaScript (SEC-01)	Données fausses attribuées au salarié, accompagnement inadapté, démarches de rectification	$G3 \times V3 = 9$, élevé : exécution démontrée par marqueur inoffensif; altération de santé non testée
R3 — Perte/indisponibilité : panne pendant l'écriture du JSON ou action malveillante via le filtre exécutable et des accès abusifs (SEC-01/02/03)	Perte du suivi, impossibilité temporaire d'accéder à ses réponses ou d'exercer ses droits	$G2 \times V2 = 4$, modéré : panne plausible et capacité d'exécution démontrée sans test destructif; restauration, sauvegardes et protections d'accès insuffisamment documentées; aucun service médical vital établi
R4 — Conservation subie : ancien salarié conservé et réauthentifiable après suppression (PRIV-05)	Perte durable de contrôle et prolongation du risque de divulgation	$G3 \times V4 = 12$, critique : maintien des données et accès reproduit

Une réutilisation défavorable par un assureur aggraverait R1, mais aucun usage assurantiel concret ni décision discriminatoire ne sont établis. Les conséquences ci-dessus sont des risques, pas des préjudices déjà constatés.

5. Mesures, vérification et risque résiduel — article 35(7)(d)

Mesure proposée	Pilote proposé	Preuve exigée avant réévaluation
M1 — Contrôles objet/rôle/entreprise, champs modifiables autorisés, suppression du filtre exécutable	Référent développement + RSSI	Tests négatifs salarié/tiers, interentreprises, élévation de rôle, accès abusifs et injection. L'entreprise d'appartenance doit être vérifiée, pas simplement déclarée par l'inscrit
M2 — Retrait des secrets des réponses/logs, mots de passe adaptés, sessions aléatoires, expirables et révocables	Référent développement + RSSI	Sentinelles absentes des sorties; tests de stockage, expiration et révocation; absence de session admin préchargée
M3 — Minimisation, information, choix/retrait santé et suppression cohérente; suspension de l'export injustifié	Responsable du traitement, conseillé par le DPO	Parcours sans consentement refusé pour la santé, refus sans pénalité, contrôle des champs, test d'effacement et de conservation justifiée

Mesure proposée	Pilote proposé	Preuve exigée avant réévaluation
M4 — Écriture robuste, sauvegardes limitées et restauration; protections des fichiers et transport	Exploitation + RSSI	Test de restauration, revue des accès, configuration du chiffrement et des sauvegardes dans l'environnement réel
M5 — Finalités, rôles, contrats, destinataires, durées et exercice des droits formalisés	Responsable du traitement, conseillé par le DPO	Décisions datées, contrats/instructions et procédures vérifiables, pas une simple approbation de principe

Cibles conditionnelles, non résultats mesurés : R1 → G4×V1 = 4 après M1–M5; R2 → G3×V1 = 3 après M1/M2/M4; R3 → G2×V1 = 2 après M1/M2/M4; R4 → G3×V1 = 3 après M2/M3/M5. Pour R3, M4 traite la panne et la restauration; M1/M2 réduisent l'action malveillante par injection, élévation ou session abusive. Les gravités ne disparaissent pas; seule la vraisemblance espérée baisse. Une réouverture de l'export ou un changement de destinataire impose une nouvelle évaluation.

6. Décision et suivi

Avis d'audit : pas de mise en service avec de vraies données de santé en l'état. Aucun risque résiduel n'est accepté ici. Le responsable réel doit vérifier les mesures, motiver sa décision et solliciter l'avis du DPO s'il est désigné; cet avis n'a pas été obtenu dans l'exercice. Recueillir, lorsque pertinent, l'avis des salariés ou de leurs représentants avec des modalités sans pression professionnelle.

Si un risque résiduel élevé demeure, consulter préalablement l'autorité selon l'article 36; ce n'est pas la notification de violation des articles 33–34, traitée en B. Réexaminer l'AIPD après correctifs, incident ou modification substantielle. Ces étapes et les avis restent à **réaliser**, conformément aux [articles 35\(2\), 35\(9\), 35\(11\) et 36](#).

Partie A.4 — Constats de non-conformité RGPD

- **Version :** 1.0 — 1er octobre 2026
- **Référence :** baseline-vulnerable, commit e16cedcf0f8adb359621240366c8f0cbb251b8c9
- **Sources techniques :** [matrice initiale](#) et [preuves d'exécution](#). Les identifiants ci-dessous regroupent les constats techniques sans les remplacer.

Méthode

Chaque fiche relie article, preuve, risque humain et gravité. **Confirmé** signifie observé sur le support; **non démontré** signifie qu'une pièce organisationnelle manque, pas qu'elle n'existe nulle part. Les preuves dynamiques sont celles déjà consignées, sans nouvelle exécution pour cette rédaction.

La gravité qualifie ici l'importance du constat : **critique** pour une exposition massive de santé ou un contrôle généralisé des accès; **élevée** pour une atteinte sérieuse à la confidentialité, aux choix ou aux droits. Ce classement de priorité n'est ni le CVSS de B ni le produit gravité×vraisemblance d'A.3. Les articles cités sont vérifiés dans les [principes, articles 5 à 9](#), les [droits, articles 12 à 22](#) et les [obligations, articles 24 à 36](#).

NC-01 — Choix marketing/tiers imposés et retrait incohérent

- **Articles :** 5(1)(a), 6(1)(a), 7(1) et 7(3), si ces usages sont fondés sur le consentement.
- **Preuve :** PRIV-07; [accounts.js](#), lignes 20–32, impose `marketingOptIn`, `marketing` et `thirdParty` à `true` sans choix envoyé. Lignes 52–58, modifier le premier champ ne met pas à jour `consents`.
- **Risque :** utilisation contre la volonté de la personne; impossibilité de prouver un choix ou un retrait cohérent.
- **Gravité : élevée.** Indicateurs artificiels confirmés; aucune campagne effective ni transmission marketing démontrée. Remplacer les valeurs imposées par un choix facultatif, spécifique, traçable et réversible.

NC-02 — Licéité de la collecte santé et de l'export non démontrée

- **Articles :** 5(1)(a), 5(2), 6 et 9(1)–(2).
- **Preuve :** [data.js](#), lignes 11–19 et 48–55, collecte puis restitue des réponses de santé sans contrôle d'un fondement santé; [interface](#), lignes 28–32 et 59–61, sans recueil explicite. Aucun justificatif d'exception de l'article 9 dans le support.
- **Risque :** perte de maîtrise d'informations médicales et usage professionnel ou assurantiel défavorable.
- **Gravité : critique.** Collecte/export confirmés; fondement externe non démontré, non présumé inexistant. Aucun consentement générique marketing ne couvre la santé. Appliquer l'analyse RT-02/RT-05 d'A.2 avant une collecte réelle.

NC-03 — Information absente des parcours fournis

- **Articles :** 12(1), 13(1)–(2).

- **Preuve** : [index.html](#), lignes 16–61 : formulaires d'inscription et de santé sans notice ni lien exposant responsable, finalités, bases, destinataires, durées et droits.
- **Risque** : divulgation de données sans compréhension des usages, destinataires ou possibilités de recours.
- **Gravité** : **élevée**. Absence confirmée dans l'interface; une information éventuellement remise hors application reste à vérifier. Ajouter une information accessible au moment de la collecte, sans confondre information et consentement.

NC-04 — Données excessives dans les réponses et exports

- **Articles** : 5(1)(c), 25(2).
- **Preuve** : PRIV-06, PRIV-04; [accounts.js](#), lignes 34, 45 et 49, renvoie l'utilisateur complet; [data.js](#), lignes 23–34 et 48–55, expose profils, passwordHash et, selon la route, questionnaires.
- **Risque** : attaques hors ligne sur les mots de passe, circulation inutile de données identifiantes et médicales.
- **Gravité** : **élevée**. Excès confirmés. Définir des réponses autorisées par usage; ne jamais retourner l'empreinte du mot de passe. La nécessité de champs tels que la date de naissance reste à justifier, pas à supposer.

NC-05 — Confidentialité et cloisonnement défaillants

- **Articles** : 5(1)(f), 25(2), 32(1)(b) et 32(2).
- **Preuve** : PRIV-01/02/03/04, SEC-01/02; [data.js](#), lignes 23–34 et 48–55 : lecture de tiers et accès interentreprises; [accounts.js](#), lignes 52–58 : auto-attribution du rôle admin; [db.js](#), lignes 32–37 : évaluation du filtre JavaScript. Chaîne SEC-02 → PRIV-04 reproduite.
- **Risque** : divulgation massive, discrimination et chantage; altération potentielle des informations.
- **Gravité** : **critique**. Accès et élévation confirmés; l'exploitation comme origine de la fuite du sujet n'est pas prouvée. Corriger ensemble autorisations, appartenance vérifiée à l'entreprise et filtre; un simple contrôle « connecté » ne suffit pas.

NC-06 — Protection insuffisante des authentifiants et sessions

- **Articles** : 5(1)(f), 32(1)(b) et 32(2).
- **Preuve** : SEC-03/05; [auth.js](#), lignes 7–21 : jeton déterministe encodé et absence d'expiration; [seed.js](#), lignes 71–72 : session admin ancienne acceptée; [db.js](#), lignes 25–28 : SHA-256 non salé.
- **Risque** : usurpation et accès prolongé à la santé d'autrui, particulièrement après compromission d'un jeton ou d'empreintes.
- **Gravité** : **élevée**. Mécanismes et réutilisation confirmés. Le RGPD n'impose pas un algorithme nommé; l'insuffisance s'apprécie au regard du risque. Prévoir stockage adapté, jetons aléatoires, expiration et révocation.

NC-07 — Mots de passe en clair dans les journaux

- **Articles** : 5(1)(c), 5(1)(f), 32(1)(b).
- **Preuve** : SEC-04; [accounts.js](#), lignes 15 et 39; [logger.js](#), lignes 6–14 : mot de passe sentinelle retrouvé dans le journal temporaire.
- **Risque** : usurpation par une personne accédant aux logs, y compris sur d'autres services en cas de réutilisation du mot de passe.
- **Gravité** : **élevée**. Journalisation confirmée, accès extérieur aux logs non démontré. Exclure les secrets à la source et contrôler fichiers/stdout; traiter les traces existantes sans détruire des preuves nécessaires à l'investigation.

NC-08 — Suppression sans effacement ni fermeture effective

- **Articles** : 5(1)(e), 12(2), 17(1), sous réserve des exceptions de 17(3).
- **Preuve** : PRIV-05; [accounts.js](#), lignes 62–64 : seul un marquage est écrit; lignes 37–45 et [auth.js](#), lignes 15–21 : reconnexion et session toujours acceptées. Compte, questionnaire, sessions et consentement conservés dans la preuve.
- **Risque** : faux sentiment de départ du service et exposition prolongée d'informations sensibles.
- **Gravité** : **élevée**. Comportement confirmé; l'API annonce un marquage, pas un effacement réalisé. Définir la procédure d'effacement lorsqu'il est dû, les exceptions motivées, la révocation et les délais. Toute demande n'exige pas la destruction immédiate de toute trace.

NC-09 — Conservation non maîtrisée dans le support

- **Articles** : 5(1)(e), 5(2), 25(1).
- **Preuve** : [db.js](#), lignes 16–23 et 40–53 : persistance sans purge; [logger.js](#), lignes 6–14 : ajout continu; RT-01 à RT-07 d'A.1 sans politique de durée fournie. PRIV-05 illustre la persistance après fermeture demandée.
- **Risque** : accumulation de profils anciens et augmentation de la durée d'exposition possible.

- **Gravité : élevée.** Absence de purge applicative confirmée; absence de politique organisationnelle ou de rotation externe non prouvée. Obtenir puis appliquer des critères de durée par finalité, y compris archives et sauvegardes; aucune durée arbitraire présentée comme légale.

Écarts documentaires à lever, sans inventer des infractions

Le support initial ne fournit pas les contrats, les décisions de rôle, l'hébergement, les garanties de transfert ou une AIPD antérieure. A.1–A.3 apportent une analyse, pas des contrats signés ni une validation réelle. Vérifier les exigences des articles 5(2), 24, 26/28 selon les rôles, 30 et 35. **Priorité élevée** : sans ces éléments, les salariés risquent de ne pas identifier leur interlocuteur ni les destinataires effectifs. L'absence d'une pièce dans le dépôt ne prouve pas son inexistence dans l'organisation.

Ne pas inventer une obligation de DPO, un transfert hors UE, des sauvegardes absentes, une lecture de tous les messages ou une cause certaine de fuite. Le défaut de relation de coaching à l'envoi est observé statiquement (data.js:38–41), mais la lecture des messages filtre bien expéditeur/destinataire (43–44). Il doit être encadré sans prétendre avoir démontré une fuite globale de messagerie.

Passage aux parties suivantes

Les preuves SEC-* et PRIV-* restent les références de B; les NC-* relient ces faits aux exigences RGPD. C devra relier chaque correction à ces identifiants et produire ses tests. Aucun constat n'est déclaré corrigé par la seule rédaction de cette partie.

Partie B.1 — Constats de sécurité

- **Version** : 1.1 — 1er octobre 2026
- **Référence** : baseline-vulnerable, commit e16cedcf0f8adb359621240366c8f0cbb251b8c9.
- **Vérification** : scénario local réexécuté le 1er octobre; douze constats dynamiques et un constat statique retrouvés. Les procédures et résultats attendus figurent dans les [preuves reproductibles](#).

Méthode et reproduction

Les [preuves reproductibles initiales](#) décrivent les requêtes et observations historiques. Leur ancien script copiait le code courant et écrivait les libellés confirmed-by-execution en dur. Depuis la [revue de fiabilisation](#), node scripts/audit/reproduce-findings.js extrait et vérifie le commit initial avant d'exécuter les scénarios préservés sur 127.0.0.1, avec données fictives. Le nouveau validateur contrôle les observations, dont la corroboration HTTP et l'identité du profil pour PRIV-03. Cette reproduction historique reste distincte de npm test, qui vérifie le code corrigé; elle ne réécrit pas les preuves des exécutions antérieures.

Les scores ci-dessous utilisent **CVSS 3.1 Base**, choisi pour une cotation reproductible à huit métriques; ce n'est pas la version la plus récente. Pas de mélange avec CVSS 4.0, ni de score environnemental faute de déploiement réel connu. Références : [spécification FIRST](#), [guide et chaînes de vulnérabilités](#). node scripts/audit/verify-cvss.js recalcule les scores et contrôle des exemples FIRST.

Conventions de scénario : les routes HTTP sont cotées réseau (AV:N), même si la preuve est confinée en local. PR:L décrit un accès authentifié ordinaire ou métier sans contrôle administratif étendu; l'inscription libre rend l'accès salarié très facile à obtenir. Selon FIRST, PR:H suppose un contrôle significatif, par exemple administratif, sur les paramètres et fichiers de l'ensemble du composant : le nom d'un rôle ne suffit pas. UI:N : pas d'action d'une autre personne pendant l'exploitation. S:U : effets cotés dans la même application et ses données. Les impacts potentiels déduits du code sont signalés sans prétendre avoir exécuté une attaque destructive ([définitions FIRST de PR et AC](#)).

Scores calculés

Constat	Score	Vecteur CVSS 3.1
SEC-01	8.8	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
SEC-02	7.1	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
SEC-03	8.2	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
SEC-04	5.5	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
SEC-05	4.7	CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N
PRIV-01 / PRIV-03	6.5	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
PRIV-02	6.5	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
PRIV-04	6.5	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Constat	Score	Vecteur CVSS 3.1
PRIV-05	4.3	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
PRIV-06	6.5	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Ce sont des évaluations d'audit, pas des scores officiels attribués par FIRST au projet. Les scores 7–8.9 sont élevés, 4–6.9 moyens. Ils ne mesurent ni la licéité ni la gravité humaine d'A.3. Les constats se recoupent : **ne pas additionner leurs scores ni compter chaque facette comme une attaque indépendante.**

Fiches et justification des impacts

SEC-01 — Injection JavaScript côté serveur

Preuve. Un salarié appelle `GET /api/users` avec le filtre `(row.auditProof='SAFE_MARKER',row.id===1)` : HTTP 200, un objet portant le marqueur. Entrée : [data.js:31–34](#); interprétation : [db.js:32–37](#). Il s'agit de JavaScript exécuté par `new Function`, pas de SQL.

Cotation. AC:L, expression directement évaluée. C:H/I:H/A:H : exécution dans le processus Node, sans bac à sable, permettant raisonnablement de compromettre les données et la disponibilité de l'application. Seule la modification inoffensive d'une propriété en mémoire a été exécutée; aucun arrêt du serveur, accès à des secrets ou commande système n'a été testé. **OWASP : A05:2025 Injection.** Correctif cible : filtres déclaratifs autorisés, sans interprétation de code.

SEC-02 — Élévation de privilèges par modification de profil

Preuve. `PATCH /api/me` avec `{"role":"admin"}` retourne le rôle administrateur; l'export suivant réussit. [accounts.js:52–58](#) applique tout champ sauf `id`.

Cotation. AC:L; C:H car le rôle obtenu ouvre l'export; I:L pour la modification d'attributs protégés du compte, sans attribuer un pouvoir général d'écriture sur les comptes tiers; A:N faute d'effet propre de disponibilité établi. **OWASP : API3:2023 / A01:2025.** La chaîne SEC-02 → PRIV-04 est explicitée en B.2, sans y ajouter SEC-01 artificiellement. Correctif : liste de champs modifiables et administration séparée des rôles.

SEC-03 — Session administrative préchargée, sans expiration

Preuve. La session fictive du seed, datée du 1er mars 2024, donne HTTP 200 sur `/api/me`; aucun champ d'expiration. [seed.js:71–72](#), [auth.js:7–21](#).

Cotation. PR:N pour le scénario précis du jeton fixe restructurable à partir du seed fourni, pas pour tout vol de session. AC:L; C:H pour les lectures offertes au compte; I:L pour ses attributs modifiables; A:N. Ces capacités découlent des routes, au-delà de la preuve de connexion. Score applicable à une instance utilisant ce seed; présence du jeton en production inconnue. La prédiction d'un jeton arbitraire fondé sur l'heure n'a pas été démontrée. **OWASP : API2:2023 / A07:2025.** Correctif : pas de session active distribuée, aléa cryptographique, expiration et révocation.

SEC-04 — Secrets en clair dans les journaux

Preuve. Une tentative de connexion avec une sentinelle fictive écrit celle-ci en clair dans le log temporaire. [accounts.js:15,39](#), [logger.js:6–14](#).

Cotation conditionnelle. AV:L/PR:L : attaquant disposant d'un accès local de lecture aux journaux, pas un lecteur HTTP anonyme. AC:L; C:H pour les authentifiants révélés; I:N/A:N pour cette divulgation seule, sans intégrer une future usurpation. Aucune exposition web des logs démontrée. **OWASP : A09:2025**, qui couvre notamment l'insertion de données sensibles dans les logs. Correctif : exclusion des secrets à la source et contrôle de tous les canaux de journalisation.

SEC-05 — Empreintes de mots de passe trop faciles à tester hors ligne

Preuve. Deux inscriptions avec le même mot de passe fictif donnent la même empreinte SHA-256 de 64 caractères; le code ne sale pas et n'applique pas de facteur de travail. [db.js:25–28](#), [seed.js:8–9](#).

Cotation conditionnelle. Le scénario coté isole le stockage faible : l'attaquant doit pouvoir lire localement le fichier JSON contenant les empreintes (AV:L). PR:L suppose qu'un compte local peu privilégié possède cette lecture; le support ne documente ni déploiement ni permissions. Si seuls un administrateur ou le compte de service y accèdent, PR:H devra remplacer PR:L. L'obtention par l'API relève plutôt de la chaîne avec PRIV-06, pas de ce vecteur local autonome.

AC:H est retenu car la récupération d'un secret utilisable dépend de la présence du mot de passe réel dans l'espace testé et d'un effort mesurable, conditions que l'attaquant ne maîtrise pas. SHA-256 sans sel rend chaque essai rapide, répétable et mutualisable, mais ne garantit pas la réussite; aucun craquage n'a été exécuté. Si le scénario évalué se limite à la capacité certaine de lancer des essais rapides, sans exiger la récupération du secret, l'impact C:H devrait lui aussi être réexaminé. Le score 4,7 décrit donc une hypothèse précise, non une extraction réseau démontrée ([FIRST, Attack Complexity](#)). **OWASP : A04:2025.** Correctif : fonction adaptée aux mots de passe, salée et à coût réglable, avec stratégie de migration.

PRIV-01 / PRIV-03 — Profils et santé lisibles entre utilisateurs/entreprises

Preuve. Un salarié AuditTenant lit `/api/users/4` : profil d'une autre entreprise et trois questionnaires, HTTP 200. [data.js:23–27](#). Deux angles du même défaut : contrôle de l'objet et cloisonnement des clients.

Cotation. AC:L; C:H compte tenu des données médicales directement exposées et des identifiants énumérables; I:N/A:N, lecture seulement. **OWASP : API1:2023 / A01:2025.** Correctif : autorisation par objet et appartenance vérifiée au client, pas un simple filtre fondé sur une entreprise autodéclarée.

PRIV-02 — Annuaire complet accessible au salarié

Preuve. GET `/api/users` retourne 65 comptes et six valeurs d'entreprise dans l'essai (63 comptes du seed et deux comptes ajoutés). [data.js:31–34](#).

Cotation. AC:L; C:H pour le répertoire intégral incluant les empreintes; I:N/A:N. **OWASP : API5:2023 / A01:2025**, accès à une fonction annoncée pour coaches/RH. Correctif : restriction métier, client et champs. Ce résultat n'établit pas que 65 personnes réelles ont subi une fuite.

PRIV-04 — Export RH non cloisonné et excessif

Preuve. Un RH obtient directement 65 lignes avec comptes et questionnaires; un salarié élevé par SEC-02 obtient la même réponse. [auth.js:32–37](#), [data.js:48–55](#).

Cotation de l'accès RH direct. PR:L est retenu : le compte doit être authentifié avec le rôle métier `rh`, mais le code ne démontre pas que ce rôle contrôle les paramètres ou fichiers de l'ensemble du composant. FIRST réserve PR:H à un contrôle significatif, notamment administratif; une fonction sensible autorisée au rôle RH ne suffit pas à l'établir. Avec AC:L, C:H et I:N/A:N, le score est **6,5**. Si l'organisation démontre que tout compte RH dispose déjà d'un tel contrôle administratif avant l'exploitation, le vecteur devra revenir à PR:H et 4,9. Le scénario salarié après SEC-02 reste une chaîne distincte. **OWASP : A01:2025 / API3:2023.** Cible A.2/A.3 : suspendre l'export tant que finalité et licéité ne sont pas établies, puis définir l'habilitation si réouverture justifiée.

PRIV-05 — Accès encore actif après demande de suppression

Preuve. Après DELETE `/api/me`, ancien jeton et nouvelle connexion fonctionnent; compte, questionnaire, deux sessions et consentement subsistent. [accounts.js:37–45,62–64](#), [auth.js:15–21](#).

Cotation de la composante sécurité. Scénario d'un détenteur d'ancien accès après fermeture demandée : PR:L, AC:L; C:L pour la lecture persistante du profil de ce compte, I:N/A:N conservateurs. Les lectures de tiers sont déjà cotées ailleurs. La conservation illicite éventuelle relève séparément de NC-08/09. **OWASP : API2:2023 / A07:2025.** Correctif : procédure d'effacement motivée et révocation effective des accès.

PRIV-06 — Empreintes exposées par les réponses API

Preuve. `passwordHash` est présent dans inscription, profil tiers et annuaire; [accounts.js:34,45,49](#), [data.js:27,34](#). Les routes renvoient les objets complets.

Cotation. Scénario de lecture des empreintes de tiers : AC:L, C:H, I:N/A:N. Le hash de son propre compte à l'inscription ne suffirait pas à justifier cet impact. **OWASP : API3:2023 / A01:2025.** Le recoupement avec PRIV-01/02/04 est assumé; cette fiche isole le défaut de sélection des propriétés. Correctif : schémas de sortie excluant systématiquement les secrets dérivés.

Constats non cotés comme vulnérabilités autonomes

PRIV-07 (consentements imposés) est un constat RGPD, traité en A.4, pas un score CVSS artificiel. CODE-01 (configuration et générateur aléatoire inutilisés) explique de fausses protections apparentes : impact déjà couvert par SEC-03 et A. Aucun score 0 ne signifie « conforme ». CORS ouvert, `localStorage`, absence de limitation de débit visible et messagerie sans relation de coaching méritent un durcissement contextualisé; aucune exploitation supplémentaire n'est prétendue démontrée ici.

Références OWASP vérifiées

Les correspondances sont notre analyse du code, fondée sur les catégories officielles : [A01:2025 accès](#), [A04:2025 cryptographie](#), [A05:2025 injection](#), [A07:2025 authentification](#), [A09:2025 journaux](#); [API1:2023 objets](#), [API2:2023 authentification](#), [API3:2023 propriétés](#), [API5:2023 fonctions](#). Ne pas intervertir les numéros des éditions 2021, 2025 et API 2023.

Partie B.2 — Risques de violation et scénarios de fuite

Version 1.0 — 1er octobre 2026. Référence : `baseline-vulnerable`, commit `e16cedcf0f8adb359621240366c8f0cbb251b8c9`.

Ce qui est établi et ce qui ne l'est pas

L'énoncé signale un fichier d'utilisateurs sur un forum. Ni ce fichier, ni URL, date, journaux de production ou preuve de correspondance avec WellWork ne sont fournis. Les essais locaux démontrent des vulnérabilités sur données fictives, pas une violation réelle ni la cause de l'événement du sujet.

Une vulnérabilité est une possibilité d'attaque; une violation implique une atteinte aux données, notamment perte, altération, accès ou divulgation non autorisés. Un téléchargement prouvé par un attaquant n'est pas toujours nécessaire : une mise à disposition publique non autorisée constitue déjà une divulgation. Référence : [RGPD, article 4\(12\)](#).

Scénarios à investiguer, sans classement de probabilité inventé

Scénario	Faits locaux qui le rendent plausible	Ce qui manque pour le relier au forum
S1 — Extraction par un salarié ou un compte créé librement	PRIV-01/02/03/06 : annuaire puis lecture de profils/questionnaires de tiers sans cloisonnement	Requêtes réelles, compte utilisé, horaires, volumes, correspondance des champs et des personnes
S2 — Export par un compte RH	PRIV-04 : rôle RH directement autorisé, export global avec santé	Auteur réel, historique exports, événements <code>insurer_export</code> , destination et éventuel détournement après réception
S3 — Salarié devenu administrateur	CHAIN-01 : SEC-02 puis PRIV-04, chaîne reproduite	Changements de rôle suivis d'exports, sessions et chronologie de production; <code>profile_updated</code> ne journalise que les noms de champs, pas une preuve complète de l'auteur réel
S4 — Rejeu d'une session préchargée ou compromise	SEC-03 : jeton du seed encore accepté; PRIV-05 : fermeture demandée sans révocation	Usage de ce seed en production, traces de session, source d'obtention du jeton; ne pas supposer que le secret de démonstration est actif ailleurs
S5 — Exécution de code via le filtre	SEC-01 : expression JavaScript exécutée; données de l'application potentiellement accessibles/altérables	Requêtes de filtre et traces système réelles; la preuve locale est seulement un marqueur inoffensif, pas une exfiltration
S6 — Compromission d'authentifiants puis accès à la plateforme	SEC-04 expose les mots de passe aux lecteurs des logs; PRIV-06 + SEC-05 facilitent un scénario de récupération hors ligne	Accès effectif aux logs/empreintes, mot de passe récupéré et réutilisation constatée. Le craquage n'est pas démontré

PRIV-05 prolonge aussi l'exposition d'anciens comptes. PRIV-07 viole les conditions d'un consentement invoqué mais ne constitue pas, à lui seul, une preuve de fuite. L'export HTTP n'est pas une preuve d'envoi à l'assureur; inversement, l'absence de code d'envoi n'exclut pas une transmission manuelle dans l'organisation.

Rattachement aux obligations RGPD

Constats	Atteinte redoutée et personnes exposées	Rattachement à A.4
SEC-01/02, PRIV-01/02/03/04	Confidentialité et, pour l'injection, intégrité/disponibilité; salariés de plusieurs clients	NC-05, articles 5(1)(f), 25(2), 32
SEC-03/04/05, PRIV-06	Usurpation, compromission de profils et données de santé	NC-04/06/07, articles 5(1)(c)/(f), 25(2), 32
PRIV-05	Accès persistants et conservation subie après départ	NC-08/09, articles 5(1)(e), 12, 17 et 32 selon les faits

Références : [principes](#), [droits](#), [sécurité](#). Une violation réelle déclenche en plus l'analyse des articles 33/34; elle ne découle pas automatiquement du seul score CVSS.

Investigation proposée et limites de l'exercice

Le RSSI ou référent incident doit préserver les traces, dates/fuseaux, empreintes et droits d'accès aux preuves avant nettoyage, puis examiner avec le responsable et le DPO un échantillon obtenu par une voie autorisée. Identifier les données réellement exposées, personnes/clients, période, lisibilité et destinataires; recouper avec sessions, exports et traces d'infrastructure disponibles. Les logs actuels sont incomplets et contiennent des secrets : accès restreint, aucune publication brute dans Git.

Ne pas retarder le confinement pendant une investigation exhaustive : restreindre les accès/export à risque et révoquer les accès compromis de façon coordonnée, en conservant les éléments utiles. Ne pas déduire une absence d'attaque d'une absence de logs. Ces actions sont **proposées**, pas exécutées sur une production inconnue. Aucun forum, partenaire ou utilisateur réel n'a été contacté dans cet audit.

Conclusion : plusieurs chemins compatibles avec une fuite existent; aucun ne peut être désigné comme sa cause. La décision de notification est développée en [B.3](#).

Partie B.3 — Violation de données et projets de notifications

Version 1.0 — 1er octobre 2026. **Exercice pédagogique : aucun incident réel confirmé par cet audit et aucune notification envoyée.** Les projets ci-dessous sont préparés pour le scénario d'une divulgation confirmée de données WellWork identifiantes et de santé. Les champs entre crochets doivent être renseignés uniquement à partir de faits vérifiés.

1. Décision motivée

Situation fournie : un signalement de fichier sur un forum, sans contenu ni chronologie accessibles. Investigation rapide indispensable; on ne peut calculer une échéance réelle à partir de la date du seed ou du présent audit. Le seul succès des preuves fictives ne déclenche pas une notification d'incident réel.

Scénario retenu pour préparer la réponse : si le signalement permet de confirmer raisonnablement une divulgation non autorisée de profils identifiables et de santé, le risque est élevé : informations intimes, contexte de travail, possibilité de discrimination, stigmatisation et chantage; diffusion publique difficilement réversible. Dans ce scénario, notifier l'autorité compétente **et** informer les personnes. Inutile d'attendre l'identification de la faille exploitée ou le décompte définitif.

Situation après qualification	Décision
Fichier seulement fictif, étranger au service ou signalement non corroboré	Consigner l'analyse et les investigations; pas de notification automatique fondée sur nos essais fictifs
Violation établie, risque pour les personnes peu probable et justification solide	Documenter la violation et la décision de ne pas notifier au titre de 33(5); réévaluer si nouveaux éléments
Violation établie avec risque, sans risque élevé	Notification article 33; pas de communication automatique article 34
Données de santé identifiantes réellement divulguées dans le scénario retenu	Notification article 33 et communication article 34, sauf exception précisément démontrée

Les [articles 33 et 34](#) fixent deux seuils distincts. La CNIL reçoit la notification sous réserve de sa compétence; en présence de traitements transfrontaliers, vérifier l'autorité compétente plutôt que déduire celle-ci de la seule langue du projet.

2. Délais, rôles et exceptions

- **T0 = prise de connaissance** : degré raisonnable de certitude qu'un incident a compromis des données personnelles, pas nécessairement certitude de sa cause. Une alerte déjà suffisamment probante peut être T0. Une investigation initiale courte est possible, mais pas un report artificiel jusqu'au rapport final ([CEPD 9/2022, §31–35](#)).
- **Responsable** : notifier sans retard indu et, si possible, sous 72 heures après T0. Ce ne sont pas 72 heures ouvrées. Si informations incomplètes, notification initiale puis compléments sans retard indu; si retard, en expliquer les motifs. Consigner faits, effets, mesures et décisions.
- **Sous-traitant** : avertir chaque responsable concerné sans retard indu après connaissance, sans attendre son propre bilan exhaustif; le délai de 72 heures de l'article 33(1) n'est pas son délai légal d'alerte au client. Assister celui-ci selon l'article 28(3)(f). Les rôles restent ceux analysés en A.2 : WellWork ne notifie pas automatiquement comme responsable de tous les traitements.
- **Personnes** : si risque élevé, communiquer dans les meilleurs délais, en termes clairs; aucun délai chiffré de 72 heures n'est fixé par l'article 34. Le responsable assume la décision, conseillé par le DPO; RSSI/exploitation fournissent les faits. Un accord entre responsables conjoints doit organiser la réponse, sans effacer leurs obligations.

Les exceptions de l'article 34(3) exigent une preuve : données rendues incompréhensibles à l'auteur de l'accès, mesures ultérieures supprimant effectivement le risque élevé, ou efforts disproportionnés remplacés par une communication publique aussi efficace. **Aucune n'est démontrée ici.** Le SHA-256 des mots de passe ne protège pas le questionnaire; corriger une route n'efface pas une copie déjà divulguée; un grand nombre de personnes ne dispense pas, à lui seul, de les informer.

L'alerte, T0 et sa justification, l'échéance T0+72 h, les décisions, envois et compléments doivent être horodatés dans le registre d'incident. Référence opérationnelle : [CNIL — notifier une violation](#).

3. Projet de notification initiale à la CNIL — article 33

À compléter puis déposer par le responsable ou son mandataire via le téléservice, si la CNIL est compétente. Ne pas joindre spontanément le fichier divulgué ou des secrets.

Objet : notification initiale d'une divulgation non autorisée de données sur la plateforme WellWork — référence [INCIDENT].

Organisme et contact. Responsable du traitement : [raison sociale, adresse, coordonnées, identifiant]. WellWork intervient comme [rôle vérifié pour le traitement]. Contact DPO ou référent : [nom/fonction, email professionnel, téléphone]. Entreprises clientes concernées et coordination : [éléments vérifiés].

Nature et chronologie. Un fichier présenté comme issu de WellWork a été signalé sur un forum le [date, heure, fuseau]. Les vérifications [éléments probants, sans données sensibles superflues] ont permis d'établir une divulgation non autorisée le [T0, heure, fuseau]. La période de compromission est [période estimée ou inconnue]. La cause technique demeure [établie avec preuve / en cours d'investigation]. Des failles d'autorisation et d'export existent dans le support audité; leur rôle dans cet incident n'est pas établi par leur seule présence.

Données et personnes. Catégories confirmées : [identité/contact/entreprise et catégories de santé effectivement présentes]. Catégories de personnes : [salariés et autres titulaires réellement concernés]. Nombre approximatif de personnes : [estimation motivée ou inconnu à ce stade]. Nombre approximatif d'enregistrements : [estimation séparée ou inconnu]. Pays et destinataires non autorisés : [connus/inconnus]. Les 63 comptes et 132 questionnaires de démonstration ne sont pas utilisés comme décompte de victimes.

Conséquences probables. La divulgation conjointe d'identité et de santé peut entraîner une atteinte à la vie privée, une stigmatisation, une discrimination professionnelle ou des tentatives de chantage. Selon les données effectivement exposées, un risque d'hameçonnage ciblé ou de compromission de compte doit aussi être considéré. Aucun de ces préjudices n'est présenté comme déjà observé sans élément probant.

Mesures. Mesures effectivement réalisées : [action, périmètre, date et preuve]. Mesures proposées, à ne pas confondre avec des actions réalisées : confinement de l'export et des accès excessifs, révocation des accès compromis, protection des journaux, conservation des preuves, correction des autorisations et analyse de l'étendue de l'incident. Si les authentifiants sont concernés, prévoir les mesures de renouvellement adaptées. Examiner une demande de retrait du fichier par une voie autorisée sans détruire les preuves utiles.

Information et suivi. Les personnes [ont été informées le... / seront informées dans les meilleurs délais selon le dispositif...]. Un complément sera communiqué dès que [périmètre, décompte, cause, mesures] sera établi, sans retard indu. Si la présente notification intervient au-delà de 72 heures après T0 : [motifs précis du retard].

4. Projet de message aux personnes — article 34

Modèle à adapter au périmètre confirmé, sans diffusion effective dans cet exercice. Utiliser un canal direct fiable et éviter d'exposer la liste des destinataires.

Objet : information importante concernant vos données sur WellWork

Bonjour,

Nous vous informons d'une divulgation non autorisée de données vous concernant utilisées dans le service WellWork. Nous en avons pris connaissance le [date]. Un fichier contenant [catégories de données confirmées pour cette personne, sans recopier ses réponses médicales] a été [circonstances vérifiées de divulgation].

Ces informations peuvent porter atteinte à votre vie privée et être utilisées pour vous adresser des messages trompeurs, vous stigmatiser ou exercer des pressions. [Indiquer seulement les risques correspondant aux données effectivement exposées.] À ce stade, [faits confirmés sur les utilisations abusives, ou absence d'information permettant de les établir].

Nous avons [mesures réellement réalisées et datées]. Nous prévoyons également [mesures encore à réaliser]. Nos investigations se poursuivent pour préciser [éléments restant inconnus]. Nous vous communiquerons les évolutions importantes et toute action supplémentaire utile.

Soyez vigilant face aux messages qui utilisent ces informations pour gagner votre confiance. Ne transmettez ni mot de passe ni code de connexion à un interlocuteur qui vous contacte. Accédez au service par son adresse habituelle. [Si les authentifiants sont effectivement concernés : précisez la procédure vérifiée de changement du mot de passe et conseillez de changer les mots de passe identiques utilisés ailleurs.] Vous n'avez pas à nous renvoyer vos données de santé.

Pour obtenir des précisions, de l'aide ou exercer vos droits, contactez [DPO ou référent, email et téléphone vérifiés]. Nous regrettons cet incident et restons disponibles pour vous accompagner.

[Nom du responsable du traitement ou de l'expéditeur mandaté]

5. Vérification avant tout envoi réel

Valider l'identité de l'émetteur, le périmètre, T0, le contact, la compétence de l'autorité et les faits; remplacer tous les crochets. Vérifier les rubriques obligatoires de 33(3) et la clarté du message de 34(2). Ne pas attendre la clôture de l'enquête pour une notification initiale requise. Conserver les accusés de réception et les versions envoyées; ne pas publier de listes de victimes, tokens ou mots de passe dans le dépôt.

Partie C.1 — Plan de remédiation priorisé

- **Version** : 1.0 — 1er octobre 2026
- **Baseline audité** : `baseline-vulnerable`, commit `e16cedcf0f8adb359621240366c8f0cbb251b8c9`
- **Branche de correction** : `remediation/rgpd-security`
- **Portée** : correctifs du support pédagogique et actions proposées. Ce document ne vaut ni recette de production, ni approbation juridique, ni décision d'acceptation d'un risque réel.

Principes de décision

La priorité combine l'exposition technique démontrée en B, la sensibilité des questionnaires de santé et les non-conformités de A.4. Un correctif de code peut fermer un chemin d'attaque sans établir la licéité du traitement. Inversement, une politique écrite ne remplace pas les tests d'autorisation.

Les échéances ci-dessous sont des **jalons proposés**, à compter d'une décision réelle de poursuivre le service. « Avant production » signifie avant toute utilisation avec des personnes ou données réelles. Aucun délai n'est présenté comme déjà accepté par WellWork ou une entreprise cliente.

Horizon immédiat — avant toute donnée réelle

Supprimer l'exécution de filtres fournis par le client

Constats concernés : SEC-01, NC-05, AIPD R2/R3 **État dans cette branche** : Réalisé et testé **Pilote proposé** : Développement + RSSI **Critère de sortie** : Rejet des expressions exécutables; seuls les filtres déclaratifs autorisés sont traités

Bloquer l'auto-attribution de privilèges et appliquer le refus par défaut

Constats concernés : SEC-02, PRIV-01/02/03, NC-05, AIPD R1 **État dans cette branche** : Réalisé techniquement; processus d'habilitation restant **Pilote proposé** : Développement + responsable métier **Critère de sortie** : Aucun accès tiers sans périmètre vérifié; entreprise déclarée sans effet d'habilitation

Remplacer les sessions faibles et supprimer toute session du seed

Constats concernés : SEC-03, NC-06 **État dans cette branche** : Réalisé et testé **Pilote proposé** : Développement + RSSI **Critère de sortie** : Jetons aléatoires, expiration, révocation et refus des comptes supprimés

Séparer les trois corrections C4

Constats concernés : SEC-04, SEC-05, PRIV-06, NC-04/06/07 **État dans cette branche** : Trois commits distincts réalisés et testés **Pilote proposé** : Développement + RSSI **Critère de sortie** : Secrets absents des logs et réponses; mots de passe nouveaux sous scrypt; transition SHA-256 testée

Suspendre l'export assureur

Constats concernés : PRIV-04, NC-02/04/05, AIPD R1 **État dans cette branche** : Réalisé dans un commit indépendant **Pilote proposé** : Responsable du traitement + développement **Critère de sortie** : Réponse sans donnée et aucune trace d'export créée; réouverture interdite sans décision documentée

Rendre l'effacement actif dans le stockage de démonstration

Constats concernés : PRIV-05, NC-08, AIPD R4 **État dans cette branche** : Réalisé et testé dans la base active **Pilote proposé** : Responsable des droits + développement **Critère de sortie** : Compte, sessions et données associées supprimés; reconnexion impossible

Invalider les faux consentements historiques et recueillir deux choix distincts

Constats concernés : PRIV-07, NC-01 **État dans cette branche** : Réalisé et testé **Pilote proposé** : Produit + DPO/conseil **Critère de sortie** : Valeurs historiques non reconnues comme accords; choix facultatifs et retraits historisés

Empêcher la collecte réelle de santé tant que les articles 6 et 9 et l'information ne sont pas établis

Constats concernés : NC-02/03, AIPD R1 **État dans cette branche :** Non réalisé : obstacle à la production **Pilote proposé :** Responsable du traitement, conseillé par le DPO **Critère de sortie :** Fondements documentés, notice article 13, nécessité des champs, destinataires, retrait/droits et AIPD validés

Qualifier le signalement de fuite et préserver les preuves

Constats concernés : B.2/B.3, scénarios S1–S6, RR-09 **État dans cette branche :** À engager sans retard; aucune qualification réelle fournie dans l'exercice **Pilote proposé :** Responsable incident + responsable du traitement, conseillé par le DPO **Critère de sortie :** Déterminer nature, périmètre et T0; si une violation avec risque est constatée, notifier dans les meilleurs délais et, si possible, sous 72 h, avec compléments ultérieurs ([CNIL](#))

Les correctifs techniques sont présents dans la branche; ils ne justifient pas à eux seuls l'ouverture du questionnaire à de vraies personnes. Tant que les conditions relatives à la santé, à l'information et aux habilitations ne sont pas satisfaites, le support doit rester limité à des données fictives.

Court terme — avant pilote, cible proposée sous 30 jours

1. **Formaliser l'habilitation.** Définir qui crée, vérifie, modifie et révoque `tenantId`, les rôles RH et les affectations coach-salarié. Conserver une preuve d'origine et une piste d'audit. Tester les appartenances absentes, falsifiées, transférées et révoquées.
2. **Décider du traitement de santé.** Identifier le ou les responsables, la finalité exacte, les articles 6 et 9 applicables, le caractère réellement facultatif et les conséquences d'un refus. Si aucun fondement n'est démontré, retirer le questionnaire plutôt que recueillir une case générique.
3. **Informé au point de collecte.** Ajouter une notice complète et accessible pour le compte, le questionnaire et les préférences; distinguer information, consentement marketing et éventuel consentement explicite santé.
4. **Minimiser.** Définir un schéma fermé pour les réponses de santé et justifier chaque champ, notamment antécédents et traitements. Les RH restent exclus des questionnaires individuels.
5. **Traiter l'historique.** Organiser le renouvellement contrôlé des mots de passe SHA-256 qui ne se reconnectent pas, protéger ou purger les anciens journaux selon les besoins de preuve, et vérifier les anciennes copies/exportations.
6. **Définir les durées.** Arrêter des critères par finalité pour comptes, questionnaires, décisions de préférence, journaux, archives et sauvegardes; tester la purge et la restauration sans relancer le seed sur une base existante.

Structuel — avant généralisation, cible proposée sous 90 jours puis en continu

- Remplacer le fichier JSON par un stockage transactionnel exploité avec comptes de service minimaux, chiffrement et sauvegardes testées; documenter l'hébergement et les transferts.
- Centraliser le cycle de vie des identités, rôles, entreprises clientes et missions de coaching; ajouter une revue périodique des habilitations et des journaux d'accès sans contenu sensible.
- Durcir l'exposition web : origines CORS autorisées, protection des jetons côté navigateur, limitation de débit, politique de secrets et supervision des anomalies.
- Encadrer contractuellement les responsables, sous-traitants, destinataires, instructions et demandes de droits; renseigner les coordonnées réelles et le DPO lorsqu'il est applicable.
- Mettre à jour l'AIPD avec les preuves de recette, l'avis des parties pertinentes et la décision motivée du responsable. Consulter préalablement l'autorité si un risque résiduel élevé demeure.
- Organiser une recette de sécurité récurrente : tests négatifs multi-rôles/multi-entreprises, migration sur copie temporaire, restauration, effacement, dépendances et revue après incident ou changement substantiel.

Conditions de passage

Un passage vers un pilote réel exige simultanément : tests techniques verts; procédure d'habilitation démontrée; base juridique santé et exception de l'article 9 documentées; information accessible; durées et droits opérables; AIPD réévaluée; décision écrite du responsable réel. En leur absence, le statut demeure **non accepté** et non « accepté faute de temps ».

Partie C.2 — Correctifs, commits et preuves

- **Version :** 1.2 — 1er octobre 2026
- **Référence des constats :** [partie B.1](#) et [matrice initiale](#)
- **Périmètre :** code corrigé de la branche de remédiation, testé sur données fictives.

Traçabilité des corrections

SEC-01

Commit : 4663155 **Correction vérifiée :** Suppression de new Function; recherche par paramètres déclaratifs et test de rejet d'une expression exécutable **Limite restante :** La validation métier des filtres autorisés reste à maintenir lors de toute extension

SEC-02

Commit : 60015bf **Correction vérifiée :** PATCH /api/me limité à firstName, lastName, birthDate; rôle, entreprise et périmètre refusés **Limite restante :** La route d'administration des rôles et son processus d'approbation restent à concevoir

SEC-03

Commit : 49aae3d **Correction vérifiée :** Jetons aléatoires de 256 bits, expiration, révocation, refus des sessions expirées/révoquées et retrait de la session du seed **Limite restante :** Cette première correction ne validait pas encore une date illisible ni la configuration de durée; complément ci-dessous

SEC-04

Commit : f06e422 **Correction vérifiée :** Mot de passe retiré des événements d'inscription/connexion et masquage récursif des clés sensibles par le logger **Limite restante :** Les journaux déjà produits doivent être traités selon l'enquête et la politique de conservation

SEC-05

Commit : bed88f7 **Correction vérifiée :** script avec sel aléatoire pour les nouveaux secrets; vérification SHA-256 héritée puis migration uniquement après authentification réussie **Limite restante :** Le premier format utilisait encore les paramètres script par défaut; complément ci-dessous

PRIV-06

Commit : e243374 **Correction vérifiée :** Présentateurs de sortie supprimant passwordHash, passwordMigratedAt et les attributs internes de périmètre **Limite restante :** Toute future route doit utiliser un schéma de sortie explicite

PRIV-01/02/03

Commit : 31d3eda **Correction vérifiée :** Refus par défaut, périmètre d'entreprise vérifié, annuaire limité, RH sans santé individuelle et coach autorisé uniquement par une affectation vérifiée **Limite restante :** company reste déclaratif et n'accorde rien. PRIV-03 n'est pas clos organisationnellement sans provisionnement fiable des périmètres et affectations

PRIV-04

Commit : 44c6623 **Correction vérifiée :** Export assureur suspendu : HTTP 503 sans donnée et sans création d'un export **Limite restante :** La finalité, les bases des articles 6/9 et le destinataire ne sont toujours pas démontrés; aucune réouverture implicite

PRIV-05

Commit : d675e3b **Correction vérifiée :** Suppression du compte et du graphe de données alors identifié dans la base active, révocation des accès et reconnexion refusée **Limite restante :** Cette première vérification ne couvrait ni la réutilisation de l'identifiant supprimé, ni les anciens comptes en suppression logique; compléments ci-dessous

PRIV-07

Commit : 8d7be25 **Correction vérifiée :** Défauts à false, invalidation des enregistrements hérités, choix marketing/tiers distincts et historique des choix/retraits **Limite restante :** Cela ne constitue pas un consentement à la santé et ne valide aucune campagne ou transmission passée

Le découpage garde volontairement SEC-04, SEC-05 et PRIV-06 dans trois commits indépendants. La suspension de l'export assureur est également distincte du correctif général d'autorisation.

Retouches issues de la recette complémentaire

Retouche	Commit	Résultat couvert
Identifiants et messages après effacement	4bd6669	Compteurs d'identifiants persistants; destinataire absent ou supprimé refusé; séquence suppression → envoi → rechargement → réinscription → rechargement testée sans réattribution ni message hérité
Anciens comptes deleted: true	975da14; test 61e7316	Réponse 404 sur la consultation individuelle, exclusion de l'annuaire, session refusée et message entrant rejeté après rechargement. Les lignes héritées restent à traiter selon la durée et la procédure d'effacement, sans réensemencer la base
Expiration des sessions	e720a94	Date absente, illisible, expirée ou session révoquée refusée; SESSION_TTL_MS validé au démarrage entre 1 ms et 24 h
Minimisation par rôle	478ab2f	Listes positives de champs; RH et coach ne reçoivent ni date de naissance ni préférence marketing; les RH restent privés des questionnaires individuels
État des préférences dans l'interface	6a2b3c8	Cases remises à zéro avant changement de compte, puis rechargées depuis l'API après connexion, inscription et retour sur la page
Paramètres script	9efa859	Nouveau format auto-descriptif <code>script\$N=32768,r=8,p=3\$...</code> ; ancien script par défaut et SHA-256 vérifiés puis remplacés seulement après authentification valide

Le profil script retenu ($N=2^{15}$, $r=8$, $p=3$, environ 32 MiB) fait partie des configurations minimales proposées par [OWASP](#). `maxmem` est fixé à 64 MiB conformément au fonctionnement documenté de [crypto.scriptsSync](#). Ce choix doit encore être mesuré sur l'infrastructure réelle; il n'est pas présenté comme universel.

Ce que vérifient les tests actuels

La suite [security-regression.test.js](#) travaille avec un fichier de base et un fichier de log temporaires propres à l'exécution. Elle couvre notamment :

- expression de filtre rejetée et filtre déclaratif accepté;
- champs de privilège refusés sur le profil;
- jetons distincts, expiration, révocation, dates stockées invalides, configuration de durée et invalidation après suppression;
- sentinelles de mot de passe absentes des journaux;
- script salé avec paramètres stockés, compatibilité de l'ancien format et migration d'un SHA-256 seulement après mot de passe correct;
- absence de secrets dans les réponses utilisateur;
- accès interentreprises refusés lorsque l'appartenance est absente, falsifiée ou modifiée;
- RH exclus des questionnaires individuels, profils tiers minimisés et coach limité à une affectation explicite vérifiée, indépendante de son employeur;
- export assureur sans donnée;
- effacement des objets associés, absence de réutilisation d'identifiant, rejet des messages orphelins et masquage des suppressions logiques historiques après rechargement;
- invalidation d'un ancien indicateur forcé à `true`, nouveau choix, retrait et persistance après rechargement.
- rechargement des préférences au retour sur la page et lors de deux changements successifs de compte dans [ui-preferences.test.js](#).

Les tests généraux de santé de l'API, d'inscription/profil et d'enregistrement d'un questionnaire complètent ces régressions. Les commandes de recette sont :

```
npm test
npm run lint
node scripts/audit/verify-cvss.js
git diff --check
```

Le seed doit être vérifié avec `DB_FILE` pointant vers un fichier temporaire. Il ne faut pas exécuter `npm run seed` sur la base locale existante pour masquer un défaut de migration ou faire passer un test.

Résultats de validation

Le commit `3d00b4b` a été vérifié sur copie propre sous Windows (Node `v24.11.0`, npm `11.12.1`) et par la [CI Linux/Windows](#).

Contrôle	Résultat
Tests du code corrigé	30 réussis, 0 échec : application, interface, outillage de preuve et références historiques
Lint	Aucun diagnostic ESLint
Calculs CVSS	10 scores du rapport vérifiés
Reproduction sur la version initiale <code>e16cedc</code>	12 constats dynamiques et 1 statique retrouvés; <code>summary.failed</code> vide

Les deux vérifications répondent à des questions différentes : `npm test` contrôle les corrections; `reproduce-findings.js` retrouve les défauts dans les fichiers extraits du commit initial et vérifiés par empreinte. Ce dernier remplace l'ancien lanceur, qui copiait le répertoire de travail et pouvait donc tester la mauvaise version.

La suite est passée de 18 tests sur `61e7316` à 30 après la revue. Les recettes intermédiaires, dont celle sur `261b27b` avec retouches locales, restent détaillées dans la [note de fiabilisation](#). Les essais utilisent des fichiers temporaires et préservent la base locale.

Ces résultats valident les comportements testés. Les décisions sur les données de santé, les habilitations et l'exploitation restent à traiter dans [C.3](#) et D.

Partie C.3 — Risques résiduels et décision

- **Version** : 1.1 — 1er octobre 2026
- **Statut général** : aucune approbation organisationnelle réelle n'est fournie ou inventée. Les statuts sont des recommandations d'audit.

Règles de statut

- **Non accepté** : obstacle à la mise en production réelle tant que les conditions ne sont pas satisfaites.
- **Proposé à acceptation** : décision encore attendue du rôle indiqué, après production des preuves demandées.
- **Hypothèse pédagogique uniquement** : tolérance limitée au support local, avec données fictives et sans destinataire réel; elle ne vaut jamais acceptation pour une production.

Registre des risques résiduels

RR-01 — Collecte de santé sans licéité ni information démontrées

Constat concerné : NC-02/03; AIPD R1; RT-02 **Mesures restantes et justification** : Établir les articles 6 et 9, la finalité, le caractère facultatif, la nécessité de chaque question, les destinataires, une notice article 13 et les droits. Les contrôles d'accès ne régularisent pas la collecte **Statut recommandé** : **Non accepté — obstacle à la production** **Rôle responsable de la décision** : Responsable réel du traitement, conseillé par le DPO; le développeur ne peut accepter ce risque **Conditions et échéance de réexamen** : Avant tout pilote ou toute donnée réelle; réexamen à chaque changement de finalité, question ou destinataire

RR-02 — Provisionnement des entreprises, RH et coaches non défini

Constat concerné : PRIV-01/02/03, NC-05, AIPD R1 **Mesures restantes et justification** : Mettre en place une source d'autorité, une double vérification adaptée, la révocation et une piste d'audit. Le refus par défaut est codé, mais aucune procédure ne prouve qui renseigne `tenantId` ou les affectations **Statut recommandé** : **Non accepté** pour une exploitation multi-entreprises **Rôle responsable de la décision** : Responsable métier des habilitations + RSSI, sous responsabilité du responsable du traitement **Conditions et échéance de réexamen** : Avant le premier rattachement réel; puis revue trimestrielle proposée et à chaque départ, mutation ou fin de mission

RR-03 — Export ou usage assureur sans justification

Constat concerné : PRIV-04, NC-02/04/05, RT-05, AIPD R1 **Mesures restantes et justification** : Maintenir la suspension; identifier destinataire, données strictement nécessaires, finalité et fondements des articles 6/9. Définir un nouveau test d'autorisation et de minimisation si réouverture **Statut recommandé** : **Non accepté** **Rôle responsable de la décision** : Responsable du traitement; DPO/conseil; RSSI pour la recette **Conditions et échéance de réexamen** : Avant toute réouverture, puis revue à chaque changement de destinataire ou contrat

RR-04 — Anciens secrets et journaux déjà créés

Constat concerné : SEC-04/05, NC-06/07 **Mesures restantes et justification :** Renouveler de façon contrôlée les comptes SHA-256 non migrés, restreindre l'accès aux logs historiques, préserver les preuves utiles puis appliquer la durée décidée. Le nouveau code ne répare pas les copies antérieures **Statut recommandé : Non accepté** tant que le périmètre réel n'est pas qualifié **Rôle responsable de la décision :** RSSI/exploitation, avec responsable incident et DPO selon le contenu **Conditions et échéance de réexamen :** Inventaire avant production; plan de traitement proposé sous 7 jours après décision de poursuite; réexamen après clôture de l'enquête

RR-05 — Stockage fichier, sauvegarde et restauration non robustes

Constat concerné : NC-09; AIPD R3; M4 **Mesures restantes et justification :** Stockage transactionnel, droits minimaux, chiffrement adapté, sauvegardes limitées et test de restauration. L'injection et les accès abusifs ont été corrigés, mais la panne et la reprise ne sont pas couvertes **Statut recommandé : Proposé à acceptation dans l'hypothèse pédagogique uniquement**, jamais avec données réelles; aucune acceptation réelle constatée **Rôle responsable de la décision :** Exploitation + RSSI; responsable du traitement pour le risque aux personnes **Conditions et échéance de réexamen :** Tolérance seulement tant que données fictives et exécution locale; réexamen avant pilote et après tout incident de stockage

RR-06 — Effacement incomplet hors base active

Constat concerné : PRIV-05, NC-08/09, AIPD R4 **Mesures restantes et justification :** Définir les exceptions de conservation, les délais, le sort des sauvegardes, journaux et preuves de retrait. Le commit supprime correctement le graphe connu du fichier actif, pas des systèmes externes inconnus **Statut recommandé : Non accepté** pour une production **Rôle responsable de la décision :** Responsable des droits + responsable du traitement, conseillé par le DPO **Conditions et échéance de réexamen :** Procédure et essai de bout en bout avant pilote; réexamen annuel proposé et après toute demande échouée

RR-07 — Surface web encore à durcir

Constat concerné : Réserves de B.1 : CORS ouvert, jeton dans localStorage, absence de limitation de débit visible **Mesures restantes et justification :** Autoriser seulement les origines nécessaires, choisir un stockage/session adapté au modèle de menace, limiter les tentatives et superviser sans secrets **Statut recommandé : Non accepté** avant exposition Internet réelle **Rôle responsable de la décision :** RSSI + responsable technique **Conditions et échéance de réexamen :** Revue de configuration avant déploiement; test d'intrusion après changement d'authentification ou d'architecture

RR-08 — Préférences sans information ni contrôle des usages aval

Constat concerné : PRIV-07, NC-01, RT-06 **Mesures restantes et justification :** Ajouter la notice correspondant aux campagnes et tiers réels; garantir que les systèmes aval lisent le dernier choix et honorent le retrait. L'historique technique ne prouve aucun usage aval conforme **Statut recommandé : Non accepté** avant toute campagne ou transmission **Rôle responsable de la décision :** Responsable marketing/tiers + responsable du traitement, conseillé par le DPO **Conditions et échéance de réexamen :** Avant activation d'un canal ou destinataire; contrôle à chaque retrait et revue annuelle proposée

RR-09 — Incident évoqué mais non qualifié

Constat concerné : B.2/B.3; scénarios S1–S6 **Mesures restantes et justification :** Préserver et recouper les éléments autorisés, déterminer les données, personnes, période et T0; décider les articles 33/34 à partir de faits. Les correctifs ne suppriment pas une copie déjà diffusée **Statut recommandé : Non accepté comme risque clos;** investigation requise **Rôle responsable de la décision :** Responsable incident + responsable du traitement, conseillé par le DPO **Conditions et échéance de réexamen :** Qualification sans retard; si violation avec risque, échéance article 33 calculée depuis le T0 réel, non depuis cet audit

Réévaluation de l'AIPD

- **R1 — divulgation :** les contrôles objet/rôle/entreprise, la limitation des champs et la suspension de l'export réduisent les chemins démontrés. Le risque ne peut toutefois pas être accepté tant que l'habilitation réelle, la licéité santé et les destinataires ne sont pas validés.
- **R2 — altération :** le filtre exécutable est supprimé et le test négatif passe. Une recette sur l'environnement déployé et une surveillance restent nécessaires avant de retenir la cible conditionnelle d'A.3.
- **R3 — perte/indisponibilité :** la composante malveillante est réduite par la suppression de l'injection, le contrôle des privilèges et les sessions renforcées. La composante panne reste ouverte faute de stockage robuste et de test de restauration.

- **R4 — conservation subie** : l'accès et les données associées sont supprimés dans la base active de démonstration. La politique de conservation, les exceptions et les sauvegardes empêchent encore de déclarer le risque clos en production.

Les valeurs résiduelles cibles proposées en A.3 ne deviennent donc pas des mesures acquises. Une nouvelle cotation doit être faite avec les preuves de l'environnement réel.

Décision proposée

Réponse à la rubrique « constats résiduels acceptés » : aucune acceptation organisationnelle réelle n'est attestée. RR-05 fait uniquement l'objet d'une proposition de tolérance pédagogique :

- **Périmètre et justification** : conserver temporairement le stockage JSON pour une démonstration locale isolée sur données fictives, afin de vérifier les corrections sans attendre une migration. Cela ne démontre pas la robustesse du stockage ni des sauvegardes; une perte du jeu de démonstration reste possible.
- **Décideur attendu** : responsable du traitement pour toute exploitation réelle, sur analyse exploitation/RSSI et avis DPO pour les risques aux personnes. Aucun accord de ces acteurs n'est fourni; l'audit ne le remplace pas.
- **Conditions et réexamen** : aucune donnée réelle ni exposition Internet; réexamen avant tout pilote, changement de périmètre ou après un incident de stockage. D-04, D-14 et D-15 prévoient l'étude, la migration et la preuve de restauration. L'acceptation réelle éventuelle devra être datée et attribuée au décideur compétent.

Cette proposition limitée à RR-05 ne vaut pas acceptation des autres risques du registre.

La branche peut servir à une recette pédagogique sur données fictives. Elle ne doit pas être présentée comme prête pour une mise en production de questionnaires de santé. La décision de passage appartient au responsable réel du traitement, après satisfaction des conditions de RR-01 à RR-09 et réévaluation de l'AIPD; aucune acceptation implicite n'est déduite du calendrier de l'exercice.

Partie D — Pilotage agile de la remédiation

Version 1.2 — 1er octobre 2026. **Plan proposé pour traiter les risques restants après les corrections de C.2.** L'équipe, les disponibilités et le budget ci-dessous sont des hypothèses de planification.

Cadre, objectif et équipe proposée

Objectif produit : démontrer les accès, usages et droits nécessaires à une décision de pilote restreint. L'échéance commerciale ne justifie pas l'ouverture d'un traitement non autorisé.

Cette planification prolonge [C.1 — actions](#), [C.2 — corrections existantes](#), [C.3 — risques résiduels](#) et la [synthèse de revue, dont MSG-01](#). Les références RR-*, NC-*, PRIV-*, SEC-* et RT-* conservent leur sens dans A à C.

D-01 revalide les acquis, sans recompter les correctifs existants comme du travail neuf. Le plan traite les limites juridiques, d'habilitation et d'exploitation. Il exclut la réouverture de l'assureur, les campagnes, les nouveaux transferts et le suivi sportif non implémenté.

Méthode : trois sprints de deux semaines, avec revue et adaptation; incidents traités immédiatement. Le Product Owner ordonne le backlog, les réalisateurs réestiment le travail. Les responsabilités et événements suivent le Scrum Guide 2020 [S1](#); durées, charges et limites de travail en cours sont nos hypothèses. Les quatre jours du devoir ne sont pas la durée d'exécution de ce plan.

Rôle proposé	Contribution et responsabilité	Disponibilité par sprint de 10 jours ouvrés
Deux développeurs full-stack — DEV	API, interface, migrations, tests et revues croisées; charge répartie entre les deux développeurs	20 jours-personne
Référent qualité — QA	Scénarios adverses et légitimes, recette indépendante de l'auteur, conservation des preuves	6 jours-personne
Ingénieur exploitation — OPS	Configuration, données héritées, restauration et supervision	6 jours-personne
Product Owner — PO	Objectif produit, ordre des travaux, clarification des règles avec les clients et suivi des décisions	3 jours-personne
Scrum Master — SM	Facilitation, résolution des obstacles et amélioration du fonctionnement	2 jours-personne
DPO/conseil indépendant	Avis sur finalités, information, droits, AIPD et incident; contrôle et alerte	3 jours-personne
RSSI/référent sécurité	Analyse des menaces, recette de sécurité et coordination technique d'incident	3 jours-personne

Six réalisateurs (PO, SM, deux DEV, QA, OPS), appuyés par deux experts distincts. Les temps partiels sont réservés au planning. QA/OPS interviennent pendant le sprint : la recette n'est pas une phase finale ni une simple auto-validation du développeur.

Le **responsable compétent selon A.2** décide des traitements et risques; ni le sponsor ni le titre de PO ne remplacent cette responsabilité. Le DPO conseille et contrôle, distinct des fonctions décisionnelles PO/RSSI [S2](#). Sa présence proposée ne démontre pas une obligation de désignation.

Dimensionnement : application fournie, pilote limité, interlocuteurs client/exploitation identifiés, sans refonte générale. D-02/D-04 peuvent imposer un nouveau chiffrage face aux volumes, contrats ou à l'architecture inconnus. Les attentes de signataires ne sont pas du temps de développement disponible.

D.1 — Backlog, epics et critères d'acceptation

Un **epic** regroupe un objectif. Une **user story** décrit le résultat attendu par un bénéficiaire. Son **abuser story** décrit un usage abusif à empêcher : ce n'est ni une attaque réelle constatée ni un second ticket à chiffrer. Les tests correspondants sont compris dans l'estimation de la story.

Epic	Résultat recherché	Tickets
E1 — Contenir et prouver la sécurité	Incident traité à temps, acquis vérifiés et exposition web maîtrisée	INC-01, SAFE-01, D-01, D-05, D-11, D-16
E2 — Justifier et expliquer les usages	Finalités, information et décisions traçables, sans réouverture implicite	D-02, D-06, D-07, D-12, D-17
E3 — Maîtriser les habilitations	Attribution, usage et révocation des accès démontrés	D-03, D-08, D-09, D-18
E4 — Maîtriser le cycle de vie des données	Conservation, effacement, stockage et reprise cohérents	D-04, D-10, D-13, D-14, D-15

Exemple — D-08, habilitations

User story : en tant que responsable des habilitations, je veux attribuer et révoquer des accès vérifiés pour protéger les salariés sans bloquer les missions autorisées.

Abuser story : en tant que salarié malveillant, je déclare une autre entreprise ou réutilise une affectation révoquée pour lire la santé d'un tiers.

Acceptation : autodéclaration sans droit; attribution interdite aux acteurs non habilités; RH sans santé individuelle; coach limité aux affectations; révocation effective dès la requête suivante; cas autorisé fonctionnel et changement tracé sans santé. Preuves : tests API et procédure d'approbation. Origine : PRIV-01/02/03, NC-05, RR-02; 6,25 JP; D-03/D-01; S2.

Les **20 fiches complètes**, dont D-13 pour la conservation, sont dans le [backlog détaillé](#) : critères, pilotes, dépendances et sources.

D.2 — Estimation et priorisation justifiées

Estimation

Un jour-personne (JP) représente **7 heures de travail**, pas une journée de délai. Les charges incluent analyse, réalisation, tests, revue et documentation. Événements et réserves sont déduits séparément; les attentes de contrats ou d'informations sont des dépendances extérieures.

DEV/QA/OPS et les experts revoient les estimations avant sélection. Les tickets de confiance faible sont réestimés après découverte; D-04 explore notamment les contraintes du stockage avant de dimensionner la migration.

Ordre de traitement

- P0** : incident et confinement, sans attendre un sprint ni un score.
- P1** : obstacles de licéité, droits, identités et protections du pilote.
- P2** : exploitation et contrôles durables. P2 signifie ordre de préparation, **pas autorisation de lancer un pilote sans sauvegarde ou restauration validée**.

Dans une même classe, parmi les tickets dont les dépendances sont levées, l'indice indicatif est $I = (2R + V) / E$. R vaut 1 à 4 : confort, maîtrise durable, risque sérieux sous conditions, puis santé/identité ou obligation bloquante. V vaut 1 à 3 : amélioration locale, fiabilité opérationnelle, puis déblocage d'un parcours ou d'une décision essentielle. E est la charge totale en JP. Ce sont des appréciations explicites de pilotage, distinctes des CVSS de B et de la cotation AIPD; leurs valeurs détaillées sont dans [planning.json](#).

Exemples : D-02 obtient $(2 \times 4 + 3) / 2,25 = 4,89$; D-08 obtient $11 / 6,25 = 1,76$. La décision de finalité précède donc utilement l'implémentation. D-17 a un indice de 3,38, mais reste en S3 car ses preuves dépendent des travaux antérieurs. D-04, P2, commence en S1 pour ne pas découvrir trop tard un stockage incompatible. L'indice aide à discuter l'ordre; il ne remplace ni dépendances, ni échéances, ni capacité des spécialistes. Le PO documente tout arbitrage.

D.3 — Capacité, sprints et dépendances

Capacité nette par sprint

DEV, deux personnes
Disponibilité brute : 20 Événements/facilitation : 2 Réserve d'imprévus : 2 Capacité de tickets : 16
QA
Disponibilité brute : 6 Événements/facilitation : 1 Réserve d'imprévus : 1 Capacité de tickets : 4
OPS
Disponibilité brute : 6 Événements/facilitation : 1 Réserve d'imprévus : 1 Capacité de tickets : 4
PO
Disponibilité brute : 3 Événements/facilitation : 0,75 Réserve d'imprévus : 0,25 Capacité de tickets : 2
DPO
Disponibilité brute : 3 Événements/facilitation : 0,5 Réserve d'imprévus : 0,5 Capacité de tickets : 2
RSSI
Disponibilité brute : 3 Événements/facilitation : 0,5 Réserve d'imprévus : 0,5 Capacité de tickets : 2
SM
Disponibilité brute : 2 Événements/facilitation : 2 Réserve d'imprévus : 0 Capacité de tickets : 0
Total JP
Disponibilité brute : 43 Événements/facilitation : 7,75 Réserve d'imprévus : 5,25 Capacité de tickets : 30

QA/OPS incluent les synchronisations quotidiennes; la réserve reste libre. Une disponibilité DEV ne remplace pas un avis DPO ou une recette QA. Au planning, répartir au plus 8 JP de tickets par développeur.

Immédiat — distinct des sprints

INC-01 et SAFE-01 mobilisent initialement DEV 1,5; QA 0,5; OPS 1; PO 0,5; DPO 0,5; RSSI 1 JP, plus 0,25 JP de coordination SM, soit **5,25 JP**. Il s'agit d'une première mobilisation à déclencher dès l'alerte, non d'une durée maximale d'enquête. Les deux actions peuvent avancer en parallèle; le confinement n'attend pas la cause exacte.

Jp0 désigne le démarrage du plan; **T0** garde le sens de B.3, prise de connaissance d'une violation. Les délais de notification suivent T0, y compris pendant un week-end, et non la fin de sprint. Le sous-traitant alerte le responsable dans les meilleurs délais; la règle de 72 heures vise, sous ses conditions, la notification du responsable à l'autorité [S3](#). Ici, aucun incident réel n'est traité ni message envoyé.

Prévision de trois sprints

Les semaines se comptent après la mobilisation initiale, sous réserve de disponibilités. Chaque sprint associe clarification, implémentation et tests; il ne s'agit pas de trois phases « analyse, code, recette ».

Sprint et objectif unique	Contenu prévu	Résultat démontrable et condition
S1 — Stabiliser un périmètre contrôlé et décider de ses usages; semaines 1–2	D-01, D-02, D-03, D-04, D-05, D-10, D-11	Acquis rejoués, durcissement web démontré, traitement de l'héritage engagé, décisions et règles prêtes pour les parcours. D-02 doit précéder D-03/D-10; D-01 précède D-11. D-05 prépare son plan de traitement en début de sprint pour la cible de 7 jours de C.3, sans détruire les preuves d'incident
S2 — Rendre les parcours et les droits contrôlables de bout en bout; semaines 3–4	D-06, D-07, D-08, D-09, D-12, D-13	Information et choix, habilitations, messagerie décidée et règles de conservation vérifiées sur données fictives. D-08 précède D-09; D-02/D-03/D-10 doivent avoir livré les décisions nécessaires. D-12 prépare les accords : leur signature reste une dépendance extérieure

Sprint et objectif unique	Contenu prévu	Résultat démontrable et condition
S3 — Démontrer la reprise et préparer une décision de pilote; semaines 5–6	D-14, D-15, D-16, D-18, puis D-17	Migration, restauration sans résurrection, exercice d'incident et contrôles durables démontrés; AIPD réévaluée. D-14 précède D-15; D-17 vient après les preuves et peut conclure au maintien du refus de lancement

S1**DEV /16 : 12 QA /4 : 3,25 OPS /4 : 3,5 PO /2 : 2 DPO /2 : 2 RSSI /2 : 2 Total /30 : 24,75****S2****DEV /16 : 15,5 QA /4 : 4 OPS /4 : 1,5 PO /2 : 2 DPO /2 : 2 RSSI /2 : 1,75 Total /30 : 26,75****S3****DEV /16 : 11,5 QA /4 : 4 OPS /4 : 4 PO /2 : 1,75 DPO /2 : 2 RSSI /2 : 2 Total /30 : 25,25**

Chemin sensible : D-02 → D-03 → D-08 → D-14 → D-15 → D-17, avec une branche D-10 → D-13. Les totaux ne prouvent pas l'ordonnancement : réserver les experts et séquencer les dépendances internes. En S3, D-15/D-18 doivent notamment fournir leurs preuves avant D-17. Le détail est en annexe.

La fin de S2 représente le point court terme d'environ 30 jours de C.1, **pas une ouverture automatique**. La cible structurelle reste avant généralisation et sous 90 jours à confirmer. Entre la fin de S3 et Jp90 : contrôler le maintien des mesures et replanifier les écarts; cette période n'est pas fictivement remplie de sprints chiffrés.

Sensibilité : si D-08 passe de 4 à 6 JP DEV et de 1 à 1,5 JP QA, S2 atteint 17,5/16 et 4,5/4. Il faut consommer explicitement une réserve disponible ou retirer/replanifier un ticket avec le PO, puis recalculer S3. Ni les tests ni la confidentialité ne servent de variable d'ajustement. Un contrat non signé ne se résout pas par l'ajout d'un développeur.

Budget prévisionnel pour préparer E

Taux journaliers **purement hypothétiques**, non issus d'un devis : DEV 600 €, QA 500 €, OPS/PO/SM 650 €, DPO/RSSI 800 €. On budgète la capacité réservée, pas seulement les tickets; événements, réserves et créneaux encore non attribués sont donc déjà inclus.

Un sprint = $20 \times 600 + 6 \times 500 + 6 \times 650 + 3 \times 650 + 2 \times 650 + 3 \times 800 + 3 \times 800 = 26\,950$ €.

Trois sprints : **80 850 €**; mobilisation immédiate : **3 487,50 €**; provision de recette/hébergement temporaire : **1 500 €**, à confirmer. Enveloppe : **85 837,50 € HT, soit environ 86 000 €**, sans ajouter une seconde réserve forfaitaire. Les 81,75 JP de tickets ne sont pas les 134,25 JP de capacité totale réservée. Le détail exact permet de vérifier les calculs, sans prétendre à cette précision sur les coûts réels.

Exclusions : coûts passés A–C, incident au-delà de la mobilisation initiale, contentieux/certification, prestations spécialisées, temps des clients/signataires, exploitation après S3 et TVA. Tout besoin supplémentaire nécessite un arbitrage avant engagement; le budget n'est pas une promesse de conformité.

D.4 — Definition of Done intégrant sécurité et conformité

Les **critères d'acceptation** sont propres à la story; la **Definition of Done (DoD)** est la règle commune de qualité [S4](#). Pour ce projet, une story ne passe à « terminé » que si :

- ses critères sont démontrés sur la version identifiée; une hypothèse non vérifiée reste indiquée et n'est pas convertie en résultat;
- le code a une revue par une autre personne, les tests légitimes et négatifs pertinents passent, et `npm test/npm run lint` restent verts; une revue documentaire tient lieu de revue de code pour un ticket documentaire, sans tests fictifs;
- les preuves indiquent commit, scénario, environnement et résultat; les constats historiques ouvrent la baseline et les corrections leur propre version;
- les champs, destinataires, droits et règles de conservation touchés sont contrôlés; l'avis DPO requis par le périmètre a été recueilli, avec décision du responsable compétent si nécessaire;
- aucune donnée réelle, aucun jeton ni secret n'entre dans Git ou les pièces de recette; le risque de régression, les migrations et le retour arrière applicables sont vérifiés;
- C.2/C.3, le registre/AIPD impactés et le ticket sont cohérents; les limites hors périmètre restent visibles et attribuées.

Un test échoué, un critère manquant ou une réserve bloquante **dans le périmètre de la story** empêchent sa clôture. Un élément incomplet retourne au backlog avec travail restant; on ne compte pas « 90 % terminé ». Les incréments intermédiaires sont utilisables dans le périmètre fictif contrôlé, pas déclarés conformes pour des données réelles.

DoD n'est pas décision de production. Maintenir des champs distincts : « ticket terminé », « correctif intégré », « déployé dans tel environnement » et « risque résiduel réévalué ». D-17 prépare une décision; son dossier peut être achevé avec une conclusion de refus. Un pilote réel exige les conditions de C.3, les accords requis, l'environnement vérifié, les avis et une décision traçable du responsable; une consultation préalable est à examiner si un risque résiduel élevé demeure [S5](#). L'export assureur n'est pas réactivé par ce jalon.

D.5 — Cérémonies, suivi et risques du projet

Fonctionnement proposé

Rendez-vous	Participants et durée proposée	Sortie attendue
Sprint Planning	Équipe de réalisation, 1 h 30; experts invités sur points nécessaires	Objectif unique, sélection selon capacités réelles, tâches et créneaux de validation
Daily Scrum	DEV/QA/OPS, 15 min par jour ouvré	Plan de la journée, dépendances et obstacles; pas un compte rendu hiérarchique
Affinement du backlog	1 h par sprint, PO et personnes concernées	Critères précisés, estimations actualisées, tickets scindés; activité continue, pas événement officiel supplémentaire
Sprint Review	Équipe et parties pertinentes, 1 h	Démonstration avec preuves, retours et adaptation du backlog, pas simple approbation d'un diaporama
Rétrospective	Équipe de réalisation, 45 min	Une amélioration concrète, responsable et contrôle au sprint suivant
Arbitrage sécurité/conformité	PO, RSSI, DPO et décideur concerné, 30 min par semaine si nécessaire	Décision écrite sur obstacle, dépendance ou changement de périmètre

Les événements ordinaires des réalisateurs représentent environ 6 h 45 par sprint et sont couverts par leur ligne de capacité. Les experts à temps partiel participent à des créneaux ciblés; leurs avis sur les tickets sont chiffrés dans les tickets. L'urgence n'attend aucun rendez-vous.

Tableau proposé : **À clarifier** → **Prêt** → **En cours** → **En revue/recette** → **Terminé**, avec état « Bloqué » et motif/date visibles. « Prêt » exige sources, critères, charge, dépendances et interlocuteur identifiés; c'est une convention locale, pas une obligation Scrum. Limiter à deux implémentations et deux revues en parallèle. Une voie urgente P0 est autorisée; son temps réel consomme la réserve puis entraîne un arbitrage de périmètre.

Indicateurs de suivi

Indicateur	Calcul/preuve et fréquence	Signal déclenchant une action
Conditions de lancement ouvertes	Nombre de conditions non satisfaites de RR-01 à RR-09 et MSG-01, avec justificatif; revue hebdomadaire	Une seule condition bloquante suffit à maintenir le refus; ne pas sommer des CVSS
Couverture des critères	Critères vérifiés / critères applicables des tickets proposés comme terminés; chaque recette	Moins de 100 % : ticket non terminé; le nombre brut de tests n'est pas une couverture
Délai de blocage	Temps depuis passage « Bloqué » et responsable de résolution; quotidien	Plus d'un jour ouvré : alerte PO/SM; incident : alerte immédiate
Capacité restante par métier	Charge restante réestimée / capacité encore disponible, sans additionner la réserve deux fois; quotidien	Dépassement : réestimer, utiliser réserve explicitement ou réduire le périmètre
Flux livré et réouvertures	Tickets réellement conformes à la DoD et tickets rouverts pour défaut; revue de sprint	Réouvertures répétées : revoir critères et tests en rétrospective
Coût prévisionnel à terminaison	Coût constaté + coût du travail restant + besoins hors hypothèses; hebdomadaire	Dépassement de l'enveloppe : arbitrage avant engagement

Ces indicateurs seront renseignés pendant l'exécution du plan.

Risques du projet et réponses

Risque de réalisation	Indice observable	Réponse et responsable
Décisions/contrats indisponibles	D-02/D-12 ou signature bloqués	PO obtient un interlocuteur et une date; sponsor arbitre. Garder fermé le périmètre non justifié; ne pas transformer un contrat manquant en validation DPO

Risque de réalisation	Indice observable	Réponse et responsable
Experts ou QA saturés	Charge dépassant la capacité de leur rôle	SM réserve les créneaux tôt; PO retire du travail ou demande une disponibilité supplémentaire chiffrée
Architecture réelle différente	D-04 révèle plusieurs instances, volumes ou contraintes non prévus	OPS/DEV livrent l'exploration et réestiment D-14/D-15; aucun engagement de migration tenu artificiellement
Incident en cours de sprint	Nouvelle alerte pertinente ou trace probante	RSSI active INC-01; PO réorganise le sprint; délais de B.3 préservés. Si l'objectif devient obsolète, le PO examine l'annulation du sprint
Effacement ou migration destructifs	Perte de relation, compte réattribué, données effacées réapparues	QA bloque la recette; OPS teste la restauration; DEV corrige sur copie fictive et conserve la preuve
Preuves fragiles ou récit IA non vérifié	Mauvais commit, lien relatif ambigu, affirmation sans test	Référent audit traite D-01; revue humaine des liens et sources; aucune erreur IA inventée pour l'annexe
Pression commerciale	Demande d'ouverture malgré un RR bloquant	Responsable compétent maintient le refus ou réduit explicitement le périmètre; un calendrier ne régularise pas un traitement

Décisions à soumettre : réserver les compétences et l'enveloppe proposée; nommer les interlocuteurs/décideurs; choisir le périmètre après D-02; maintenir les fonctions non justifiées fermées; examiner les preuves à chaque revue.

Annexe 1 — Transparence IA

Version 1.3 — 1er octobre 2026. Cette annexe couvre l'audit, les corrections, les parties A à E et la préparation du rendu.

1. Outils utilisés et contributions

L'IA a participé substantiellement à l'analyse, à la rédaction et au développement, et pas seulement à la correction orthographique. Plusieurs conversations ont été utilisées pour séparer propositions, implémentations et revues; une seconde réponse d'IA ne constitue pas une validation indépendante.

Outil et usage	Parties concernées et productions
Codex, assistant de développement OpenAI dans l'espace de travail	Lecture de l'énoncé et du code, préservation de la version initiale, audit, assistance aux textes A–C, correctifs et tests, revue de D, vérification du barème, consolidation documentaire, présente annexe et présentation E (texte, mise en page HTML/PDF, notes orales et script de rendu)
ChatGPT, autre conversation avec connexion GitHub	Revue sur review/fiabilisation-audit : fiabilisation des preuves, tests et workflow; rédaction de D sur docs/partie-d-agile : backlog, capacité, budget et sources
Navigation Web pilotée par les assistants	Vérification des références CNIL/RGPD/CEPD, FIRST, OWASP, Scrum et GitHub utilisées dans les documents; ces organismes sont les sources, pas des outils d'IA
Git, terminal PowerShell, scripts Node/Python et GitHub Actions, utilisés par les assistants	Comparaison des versions, calculs et contrôles reproductibles. Ces outils d'exécution ne sont pas des modèles génératifs et leurs résultats ne prouvent pas à eux seuls la conformité

Les versions exactes des modèles de chaque conversation n'ont pas été consignées de façon fiable : aucun numéro de modèle n'est reconstitué. Les sources documentaires de la revue et de D sont conservées dans le [complément de revue](#) et les [sources et contrôles de D](#).

2. Principales requêtes formulées

Les demandes ci-dessous sont des **reformulations synthétiques**, non des citations intégrales. Elles reprennent les échanges disponibles et les journaux de travail; les prompts complets des autres conversations ne sont pas tous conservés.

Étape	Demande principale	Effet recherché
Audit initial	Comprendre le projet et examiner les éléments susceptibles d'induire l'analyse en erreur avant de traiter le sujet	Vérifier les mécanismes réellement utilisés, sans déduire une protection du seul nom d'une fonction ou d'un commentaire
Préservation	Sécuriser le point de départ et établir les preuves	Garder une version initiale identifiable, travailler sur une branche et isoler les essais
A et B	Vérifier les parties rédigées, notamment la longueur d'A.1, leur conformité à l'énoncé et les risques de perdre des points au barème	Relier chaque constat au projet et aux sources; distinguer faits, hypothèses et limites
C	Transmettre les corrections à la conversation d'implémentation, puis tester les problèmes évoqués et leurs corrections	Obtenir des correctifs traçables et des preuves de non-régression
Revue et D	Examiner la pertinence de l'audit, des corrections et de D produits par l'autre conversation; implémenter les recommandations retenues	Revoir l'outillage, les références, les stories et les calculs sans inventer de règles métier
Clôture	Vérifier le fond, actualiser les statuts, distinguer recettes historiques et actuelles, puis enregistrer et publier les corrections	Éviter les contradictions entre dossier, commits et résultats
Présente annexe	Finaliser l'annexe de transparence IA	Déclarer les contributions, les demandes et les erreurs corrigées, sans inventer de traces
E	Faire la présentation de cinq minutes et préciser si le support sera un PDF	Produire cinq diapositives pour la direction, une source modifiable et des notes de répétition

La demande initiale parlait de « pièges » posés par l'IA à l'origine du projet. L'audit établit des comportements et des incohérences observables, **pas une intention de tromper** de cet auteur supposé.

3. Erreurs et imprécisions détectées et corrigées

Les cas IA-01 à IA-05 proviennent des fragments consignés pendant la revue d'A.2 dans le journal préparatoire local `03-journal-ia-phase-initiale.md`. Ils sont repris ici pour rendre l'annexe autonome : cette trace n'est pas un export intégral des conversations, et les crochets signalent les coupures déjà présentes dans le journal. Les cas IA-06 et IA-07 disposent en plus d'un historique Git vérifiable.

Ces corrections sont issues du processus de revue assistée. Elles ne sont pas présentées comme sept découvertes faites personnellement et sans aide par l'étudiant.

IA-01 — Confondre choix techniques et responsabilité du traitement

Fragment conservé : « WellWork devient toutefois responsable [...] par exemple [pour] ses propres opérations de sécurité ».

Correction : le choix d'outils ou de mesures techniques ne suffit pas à changer le rôle. Distinguer l'exécution sur instruction d'une finalité autonome décidée par WellWork. Correction intégrée dans [A.2](#), hypothèse générale et RT-07. Justification : [CNIL — identifier son rôle](#), distinction des moyens essentiels et non essentiels.

IA-02 — Présenter le contrat comme une base préférable par principe

Fragment conservé : « L'article 6(1)(b) serait préférable seulement si un contrat [...] lie directement le salarié ».

Correction : remplacer « préférable » par « applicable sous conditions » : nécessité objective et contrat auquel la personne est partie. L'existence d'un contrat ne crée pas une priorité automatique sur les autres bases. Correction intégrée dans A.2, RT-01. Justification : [article 6\(1\)\(b\)](#) et [CNIL — absence de hiérarchie entre bases légales](#).

IA-03 — Déclarer une donnée inutile sans connaître tous les besoins

Fragment conservé : « la date de naissance inutile ».

Correction : sa nécessité n'est **pas démontrée** dans le support; cela ne permet pas d'exclure tout usage justifié. A.2, RT-01, demande cette justification. Preuve du champ : [comptes de la version initiale, lignes 12–25](#). Justification : [article 5\(1\)\(c\), minimisation](#).

IA-04 — Oublier que stocker un message constitue déjà un traitement

Fragment conservé : « Si WellWork prévoit ou exploite des messages de santé ».

Correction : dès que le contenu stocké comporte des données de santé, l'analyse de l'article 9 s'impose aussi sans exploitation médicale. Correction intégrée dans A.2, RT-03. Preuve : [insertion des messages, lignes 38–41](#). Justification : [article 4\(2\), définition du traitement](#) et [article 9](#).

IA-05 — Réduire excessivement l'exception de l'article 9(2)(h)

Fragment conservé : « L'article 9(2)(h) ne peut être invoqué sans cadre de soins ».

Correction : cette exception couvre aussi, notamment, la médecine préventive ou du travail; vérifier la finalité admissible, le fondement prévu et les garanties de secret. A.2, RT-02, ne présume pas qu'un coach bien-être remplit ces conditions. Justification : [articles 9\(2\)\(h\) et 9\(3\)](#).

IA-06 — Valider un faux positif possible dans l'outil de preuve

Production concernée : le validateur issu de la revue ChatGPT confirmait PRIV-03 à partir de deux indicateurs booléens, sans corroboration HTTP. L'expression historique `company !== 'AuditTenant'` peut être vraie lorsque `company` est absent d'une réponse d'erreur.

Correction : exiger aussi les observations réussies du profil et de l'annuaire. Le contre-exemple HTTP 403 doit être rejeté; le scénario réellement vulnérable doit rester confirmé. Source avant correction : [validateur, commit 261b27b](#). Preuve de correction : [commit 7b8c3fe et ses trois tests](#). Il s'agit d'une erreur de preuve, pas d'une nouvelle faille de l'application.

IA-07 — Écrire une abuser story du point de vue du lecteur trompé

Production concernée : D-01 décrivait un lecteur acceptant une preuve erronée, sans décrire l'acteur à l'origine de l'abus.

Correction : décrire le contributeur négligent ou malveillant qui présente les résultats d'un mauvais commit comme valides. Le critère vérifie ensuite la provenance des preuves. Sources : [formulation initiale](#) et [correction 730c79b](#), rapprochées de l'exigence d'abuser stories de l'[énoncé, page 2](#). C'est une amélioration de conception du scénario, pas une obligation juridique.

Les difficultés de commande PowerShell ne sont pas utilisées pour remplir le minimum de cinq erreurs de contenu. La mention « injection SQL » n'est pas attribuée à l'IA, faute de sortie initiale conservée permettant cette attribution.

4. Vérifications, intervention personnelle et limites

Contrôles outillés. Sur une copie propre du commit `3d00b4b`, la recette locale a réussi : 30 tests, lint sans diagnostic, 10 scores CVSS recalculés, 12 constats dynamiques et 1 statique retrouvés sur la version initiale vérifiée. La [recette GitHub du même commit](#) a réussi sous Linux et Windows. Les recettes antérieures restent datées séparément dans [C.2](#); ces succès ne mesurent ni une conformité globale ni une compréhension personnelle.

Intervention déclarée par l'étudiant. Les échanges montrent des demandes d'explication, de réduction des textes et de vérification par rapport au barème. Avant cette annexe, l'étudiant a déclaré avoir consulté le site de la CNIL pour contrôler les problèmes RGPD, puis reproduit les comportements graves sur les fonctions originales. Le détail de chaque essai personnel et ses captures n'a pas été fourni dans ces échanges : aucune liste exhaustive de tests personnels n'est donc attestée ici.

Limites assumées. Les recherches, calculs, relectures et tests effectués par les assistants ne sont pas réattribués à l'étudiant. Les cinq corrections juridiques ont été rapprochées des sources officielles lors de la consolidation; les deux autres sont rattachées au code et à l'historique. Aucun avis réel de DPO, contrat signé, incident de production confirmé ou sprint exécuté n'est inventé. Les hypothèses d'équipe et de budget restent celles de D.

Préparation du rendu. L'assistant a rédigé les cinq diapositives de E et les notes orales, puis créé la mise en page et les scripts de génération des deux PDF. Il a contrôlé la pagination, les débordements et les liens. À la demande de l'étudiant, il a ensuite allégé les répétitions et les commentaires de procédure, en conservant les preuves et les limites de fond. L'historique Git d'origine a été retenu pour la remise.

La relecture finale et la répétition chronométrée de la présentation restent à effectuer par l'étudiant.

Annexe 2 — Backlog détaillé

Version 1.0 — 1er octobre 2026. À lire avec le [corps de D](#). **Tous les tickets sont proposés, aucun n'est exécuté par la rédaction.** Les charges sont les hypothèses de [planning.json](#); elles incluent les critères de l'abuser story, pas une seconde estimation. Le pilote coordonne le ticket; il ne se substitue pas au responsable du traitement pour les décisions qui lui appartiennent.

Sources du périmètre : [C.1](#), [C.2](#), [C.3](#), [A.2](#), [A.3](#), [B.3](#) et [MSG-01](#). Les scénarios d'abus ci-dessous sont des critères de conception, pas de nouvelles vulnérabilités prétendument démontrées.

Réponse immédiate — pas un « sprint 0 »

INC-01 — Qualifier immédiatement le signalement

E1; P0; 2,5 JP; pilote RSSI/référent incident; responsable des décisions : responsable du traitement selon A.2. Dépendance : aucune, à déclencher dès l'alerte. Origine : RR-09, B.2/B.3, scénarios S1–S6.

User story : en tant que responsable d'incident, je veux qualifier le signalement et préserver les éléments disponibles pour déclencher les bonnes mesures sans attendre une enquête exhaustive.

Abuser story : en tant qu'auteur d'une fuite, je profite de l'attente du prochain sprint ou du nettoyage des journaux pour prolonger l'exposition et rendre l'analyse plus difficile.

Acceptation : chronologie avec dates/fuseaux, faits et inconnues séparés; preuve protégée et accès tracés; T0 justifié s'il est déterminable; responsabilités d'alerte et décisions des articles 33/34 consignées; notification initiale et compléments préparés selon B.3 lorsque requis. Pas de copie de santé ni de secret dans Git. L'absence d'élément réel dans l'exercice n'est ni une cause identifiée ni une violation démontrée. Preuve attendue : fiche d'incident et exercice horodaté, ou traces réelles autorisées dans un environnement approprié. L'enveloppe ne promet pas la clôture de l'enquête.

SAFE-01 — Maintenir le périmètre fictif et contenir une exposition éventuelle

E1; P0; 2,5 JP; pilote OPS, appui RSSI/DEV. Dépendance : aucune; parallèle à INC-01. Origine : RR-01/03/07, C.1.

User story : en tant qu'exploitant, je veux un périmètre explicitement autorisé afin d'éviter qu'un support pédagogique soit ouvert à des salariés réels.

Abuser story : en tant qu'utilisateur non autorisé, j'accède à une instance de démonstration accidentellement exposée et j'utilise ses fonctions de collecte ou d'export.

Acceptation : environnement, données et accès inventoriés; instance de démonstration isolée et jeu fictif confirmé; export maintenu fermé; si une instance réelle est découverte, décision immédiate de confinement coordonnée avec l'incident, sans effacer ses preuves. Vérifier l'inaccessibilité hors périmètre et le fonctionnement autorisé. Ne pas affirmer qu'une production inconnue a été arrêtée. Preuve : checklist d'environnement et essais d'accès. Le dispositif conservatoire est disponible avant les sprints, même si la décision métier santé reste ouverte.

Sprint S1 — Stabiliser et décider

D-01 — Revalider les acquis et figer les preuves

E1; P1; 2 JP; pilote QA. Dépendance : SAFE-01. Origine : C.2, note de fiabilisation; SEC-01 à SEC-05, PRIV-01 à PRIV-07; RR-02/03 pour le maintien des protections.

User story : en tant qu'auditeur, je veux rejouer les preuves et les tests sur les bonnes versions pour distinguer faille initiale et correction intégrée.

Abuser story : en tant que contributeur négligent ou malveillant, je présente des résultats issus du mauvais commit comme des preuves valides afin de faire accepter une correction non démontrée.

Acceptation : baseline et candidat identifiés par SHA; reproduction historique et tests corrigés séparés; résultats négatifs effectivement détectés; liens de A/B vérifiés vers le commit initial et les lignes pertinentes; résultats expurgés conservés avec environnement. Une erreur d'outillage devient un écart, pas un résultat vert inventé. Preuve : sorties de recette et index de liens. Cette story maintient les acquis documentaires et techniques, sans les recompter comme des correctifs neufs de C.2.

D-02 — Décider des finalités et du périmètre licite

E2; P1; 2,25 JP; pilote PO, avis DPO; décideur : responsable compétent. Pas de dépendance interne. Origine : RT-02/05, NC-02/03, RR-01/03, A.2.

User story : en tant que responsable du traitement, je veux décider quels usages sont justifiés afin de ne développer que les parcours autorisés.

Abuser story : en tant que décideur pressé, je traite le consentement marketing ou le contrat B2B comme une permission générale de traiter la santé.

Acceptation : matrice finalité/données/destinataires/rôle/base article 6/exception article 9 avec pièces et inconnues; décision motivée sur le questionnaire : autorisé sous conditions satisfaites, retiré, ou maintenu fermé; refus sans conséquence défavorable examiné si consentement retenu; export assureur toujours suspendu dans cet horizon. Preuve : note décisionnelle et avis attribué au bon rôle. Un dossier incomplet peut conduire à une décision de maintien fermé, jamais à une autorisation présumée. Les contraintes extérieures restent enregistrées.

D-03 — Définir le provisionnement et la règle MSG-01

E3; P1; 3 JP; pilote PO/responsable métier des habilitations. Dépendance : D-02. Origine : PRIV-01/02/03, NC-05, RR-02 et MSG-01.

User story : en tant que responsable métier, je veux préciser qui attribue et révoque chaque habilitation, afin que les développeurs ne déduisent pas les droits d'un champ déclaré.

Abuser story : en tant que salarié malveillant, j'utilise une entreprise ou une mission de coaching non vérifiée pour contacter ou consulter un tiers.

Acceptation : matrice rôle/objet/entreprise/affectation; source d'autorité, approbateur, justificatif, révocation et transfert de périmètre définis; rôle de l'administrateur explicitement délimité. MSG-01 tranche si les messages libres sont voulus; sinon définit les relations autorisées, exceptions et effets de la révocation. Preuve : décision métier relue par RSSI/DPO dans leur périmètre et exemples autorisé/interdit. Aucune restriction de messagerie n'est inventée avant cette décision.

D-04 — Lever les inconnues de stockage et reprise

E4; P2; 3,75 JP; pilote OPS/DEV. Pas de dépendance interne. Origine : NC-09, RR-05/06, AIPD R3/M4.

User story : en tant qu'exploitant, je veux vérifier les contraintes d'hébergement et de reprise avant de m'engager sur une migration.

Abuser story : en tant qu'opérateur négligent, je choisis un stockage inadapté au nombre d'instances et je promets une restauration sans l'avoir éprouvée.

Acceptation : nombre d'instances, volumes et contraintes collectés ou déclarés inconnus; décision d'architecture justifiée; prototype transactionnel isolé; objectifs chiffrés de perte de données admissible et de délai de reprise proposés puis soumis au responsable; étapes de migration et retour arrière évaluées. Les critères de succès D-14/D-15 reprennent ces valeurs, pas des durées inventées comme légales. Preuve : note d'exploration et petit essai reproductible. Si les hypothèses changent, livrer l'analyse et une réestimation, pas une fausse migration terminée.

D-05 — Traiter les authentifiants et journaux hérités

E1; P1; 5,75 JP; pilote RSSI/OPS. Dépendance : INC-01 pour les consignes de préservation, **pas sa clôture complète**. Origine : SEC-04/05, NC-06/07, RR-04.

User story : en tant qu'exploitant, je veux traiter les anciens mots de passe et journaux qui ne sont pas réparés par le nouveau code.

Abuser story : en tant qu'attaquant ayant obtenu une ancienne copie, je continue à exploiter des secrets qui n'ont jamais été renouvelés.

Acceptation : inventaire des formats hérités et copies accessibles; plan de traitement préparé au début de S1, pour la cible sous 7 jours de C.3; renouvellement contrôlé après vérification appropriée d'identité, sans prétendre reconstruire un mot de passe depuis son hash; révocation des accès concernés; conservation des traces utiles, accès restreints et purge selon décision documentée. Preuve : fixture héritée sans reconnexion, traitement vérifié et rapport sans secrets. Les copies détenues par un tiers ne sont pas présentées comme effacées.

D-10 — Arrêter les règles de conservation et les droits

E4; P1; 2,25 JP; pilote responsable des droits/PO, avis DPO. Dépendance : D-02. Origine : RT-01 à RT-07, NC-08/09, RR-05/06.

User story : en tant que salarié, je veux connaître le sort de mes informations et pouvoir exercer les droits applicables.

Abuser story : en tant qu'organisation négligente, je garde toute information « au cas où » ou j'efface une preuve indispensable sans justification.

Acceptation : pour chaque catégorie, finalité, événement de départ, durée ou critère, base active/archive/sauvegarde, accès et règle d'exception; procédure de demande avec identité vérifiée de manière proportionnée, décision motivée et délai applicable; interlocuteur et responsabilités documentés. Preuve : tableau approuvé ou décision de maintien fermé pour les éléments non résolus. D-13 ne programme aucune durée légale forfaitaire non justifiée. L'avis DPO ne remplace pas la décision du responsable.

D-11 — Durcir le périmètre web sans régression

E1; P1; 5,75 JP; pilote DEV, recette RSSI/QA. Dépendance : D-01. Origine : RR-07, réserves B.1/C.1.

User story : en tant qu'utilisateur autorisé, je veux me connecter et utiliser le service sans exposition évitable de mon accès.

Abuser story : en tant qu'attaquant, je multiplie les tentatives ou exploite un jeton exposé par un parcours web mal configuré.

Acceptation : origines nécessaires et modèle de session décidés à partir des menaces; limitation des tentatives mesurée avec seuils configurables et reprise légitime; contrôle des secrets dans URL/journaux; tests des origines autorisées/interdites et des parcours valides. CORS n'est pas présenté comme un contrôle d'autorisation du serveur. Un changement éventuel vers des cookies traite aussi le risque CSRF et ne dégrade pas la révocation. Preuve : note de choix, configuration et tests ciblés. Aucune architecture navigateur n'est imposée par cette seule fiche.

Sprint S2 — Parcours et droits

D-06 — Encadrer le questionnaire selon la décision santé

E2; P1; 6,5 JP; pilote DEV/PO, avis DPO. Dépendance : D-02 et ses pièces nécessaires. Origine : RT-02, NC-02/03, RR-01, AIPD M3.

User story : en tant que salarié, je veux un questionnaire limité à une finalité expliquée et réellement autorisée.

Abuser story : en tant que service trop intrusif, je collecte des antécédents sans nécessité ou contourne un refus par un appel direct à l'API.

Acceptation : sans décision favorable étayée, interface et API de collecte restent fermées ou sont retirées du périmètre; si traitement autorisé, schéma fermé et justification de chaque champ; conditions de l'article 9 et éventuel consentement explicite respectées; refus/retrait effectifs selon la base retenue, sans pénalité professionnelle; tests directs de l'API, pas seulement d'une case d'interface. Preuve : parcours accepté/refusé/retrait et décision source. Le budget couvre une mise en œuvre limitée sur le support; un modèle métier différent entraîne une réestimation.

D-07 — Informer et respecter les choix marketing/tiers

E2; P1; 3,75 JP; pilote PO/DEV, avis DPO. Dépendance : D-02. Origine : NC-01/03, PRIV-07, RR-01/08.

User story : en tant qu'utilisateur, je veux comprendre les usages et retrouver mon dernier choix sans être inscrit de force à une campagne.

Abuser story : en tant que destinataire de données, j'utilise une ancienne valeur forcée à vrai pour ignorer un retrait.

Acceptation : notice complète, accessible avant la collecte, adaptée au compte et aux usages effectivement décidés; choix facultatifs distincts et information versionnée associée à la preuve; retrait et changement de compte testés; anciens indicateurs invalidés non réutilisés. Aucun marketing ou transfert réel n'est activé dans ce périmètre. Si un système aval existe réellement, son contrat d'interface doit honorer le choix courant et le retrait avant activation; faute de preuve, activation bloquée. Preuve : notice, tests du parcours et état des usages aval. Une simple préférence enregistrée ne vaut pas licéité générale.

D-08 — Implémenter les habilitations et leur révocation

E3; P1; 6,25 JP; pilote DEV, recette QA/RSSI. Dépendances : D-03, D-01. Origine : PRIV-01/02/03, NC-05, RR-02.

User story : en tant que responsable des habilitations, je veux attribuer et révoquer des droits sur la base d'un rattachement vérifié.

Abuser story : en tant que salarié, je m'autodéclare dans une autre entreprise ou je garde les droits d'une affectation révoquée.

Acceptation : aucun privilège issu de `company` autodéclaré; opération d'habilitation interdite à un acteur non autorisé; approbation et origine vérifiables; tests salarié/tiers, RH hors périmètre, coach sans mission; RH toujours sans questionnaires individuels; retrait ou transfert appliqué immédiatement à la prochaine requête même avec une session active. Le cas métier autorisé reste fonctionnel. Preuve : tests API et journal de changement sans santé. Un outil de provisionnement limité suffit; une refonte IAM complète n'est pas comprise dans cette charge.

D-09 — Appliquer la règle de messagerie décidée

E3; P1; 3 JP; pilote DEV/PO. Dépendances : D-03 puis D-08 dans S2. Origine : RT-03, MSG-01, RR-02.

User story : en tant que salarié ou coach, je veux échanger selon les relations de service autorisées.

Abuser story : en tant qu'utilisateur indésirable, je contacte un salarié hors relation autorisée ou réutilise une ancienne relation révoquée.

Acceptation : règle MSG-01 transcrite et testée; si une relation est requise, refus sans relation, après révocation ou avec un destinataire supprimé; échange autorisé fonctionnel; lecture toujours limitée aux participants. Si l'envoi libre est explicitement retenu, justification et protections contre les abus validées et testées, sans inventer une isolation qui n'existe pas. Preuve : décision et tests correspondants. Aucune lecture globale de messages n'est prétendue démontrée par le défaut initial.

D-12 — Documenter les prestataires et préparer les accords

E2; P1; 3 JP; pilote PO, appui DPO/OPS/RSSI. Dépendances : D-02/D-04. Origine : A.1/A.2, RR-01/03/08 et réserves d'hébergement de C.1.

User story : en tant que responsable du traitement, je veux connaître les intervenants et disposer des accords nécessaires avant de leur confier des données.

Abuser story : en tant qu'organisation pressée, je confonds un brouillon d'accord et un contrat signé, ou je conclus qu'aucun transfert n'existe parce que le code ne montre pas d'appel externe.

Acceptation : inventaire hébergement, pays, support, sauvegardes, sous-traitants et destinataires avec preuves ou inconnues explicites; qualification et accords préparés selon les rôles; clauses d'instructions, incidents, droits et fin de service; suivi des signatures et pièces manquantes. Preuve : dossier prêt pour décision et tableau des dépendances externes. La story de préparation peut être achevée; les signatures et garanties nécessaires restent des conditions indépendantes de D-17. L'assureur reste suspendu et les campagnes non activées.

D-13 — Automatiser les durées et les demandes de droits

E4; P1; 4,25 JP; pilote DEV/OPS, critères métier validés en D-10. Dépendances : D-10/D-01. Origine : PRIV-05, NC-08/09, RR-06.

User story : en tant que salarié sortant, je veux que mes données et ma demande soient traitées selon les règles annoncées.

Abuser story : en tant qu'opérateur négligent, je lance une purge sans échéance définie ou je conserve les comptes supprimés historiques indéfiniment.

Acceptation : règles D-10 configurées; tests juste avant, à et après l'échéance avec horloge contrôlée; données actives nécessaires préservées; exceptions motivées; traitement des anciennes suppressions logiques; exécution répétée sans effet indésirable; identité et délais de demande suivis. Preuve : fixtures comparées et compte rendu de demande. Les tests d'effacement existants restent actifs. L'effacement des sauvegardes est traité en D-15; cette story ne le prétend pas réalisé.

Sprint S3 — Reprise et décision

D-14 — Migrer le stockage sans perdre les protections

E4; P2; 9,75 JP; pilote DEV/OPS. Dépendances : D-04/D-08/D-13. Origine : NC-09, RR-05/06, AIPD R3/M4.

User story : en tant qu'exploitant, je veux un stockage transactionnel adapté aux contraintes décidées, sans perdre les protections obtenues.

Abuser story : en tant qu'opérateur, je remplace le JSON en oubliant les habilitations, les suppressions ou l'invalidation des anciens choix.

Acceptation : migration d'une copie représentative fictive; conservation des relations, identifiants, choix et révocations; transactions testées avec interruption d'une opération; mêmes tests de confidentialité et de durée; comptes de service et permissions minimaux; retour arrière éprouvé sans ressusciter de droits révoqués. Preuve : rapport comparatif avant/après et test de reprise de migration. La charge suppose l'architecture limitée validée en D-04; besoins multi-instances ou contraintes nouvelles réouvrent le chiffrement.

D-15 — Restaurer sans réactiver des données effacées

E4; P2; 5,25 JP; pilote OPS, recette QA. Dépendances : D-14/D-13/D-10. Origine : RR-05/06, AIPD R3/R4.

User story : en tant que salarié, je veux retrouver un service fonctionnel après incident sans que mes données effacées redeviennent accessibles.

Abuser story : en tant qu'exploitant, je restaure une ancienne copie et réactive silencieusement un compte ou un consentement supprimé.

Acceptation : sauvegarde protégée et restauration dans un environnement isolé; délai et perte de données mesurés contre les objectifs chiffrés D-04; règles d'effacement/retrait/révocation réappliquées avant ouverture des accès; copie expirée traitée selon D-10; exercice échoué bloque la recette. Preuve : chronologie, mesures et vérification des comptes/données sentinelles sans contenu réel. Une politique de sauvegarde écrite seule ne clôt pas RR-05/06.

D-16 — Exercer la réponse aux incidents

E1; P2; 3 JP; pilote RSSI avec PO/DPO/OPS. Dépendances : INC-01/D-05. Origine : RR-09, B.3.

User story : en tant que responsable d'incident, je veux une chaîne d'alerte éprouvée pour ne pas découvrir les responsabilités pendant une crise.

Abuser story : en tant qu'auteur d'une fuite, je profite d'une alerte ignorée ou d'une notification reportée jusqu'au bilan technique final.

Acceptation : exercice sur table à scénario fictif; alerte, T0 ou inconnue justifiée, destinataire responsable, décisions 33/34 et compléments simulés; acteurs joignables ou suppléance identifiée; temps mesurés et écarts transformés en actions. Aucun véritable message aux personnes/CNIL n'est envoyé pendant la recette. Preuve : compte rendu et plan d'amélioration. Ce travail préventif de S3 ne retarde jamais le traitement immédiat du signalement en INC-01.

D-18 — Rendre les contrôles durables et supervisés

E3; P2; 4 JP; pilote OPS/RSSI, concours PO/DPO. Dépendances : D-08/D-11. Origine : RR-02/07/08, C.1 structurel.

User story : en tant que responsable du service, je veux des contrôles reproductibles et attribués pour éviter le retour des écarts après l'audit.

Abuser story : en tant qu'utilisateur ayant quitté une mission, je conserve des droits parce qu'aucune revue n'est organisée et qu'aucune alerte n'est traitée.

Acceptation : revue des habilitations et contrôles de retrait définis, avec fréquence et responsable; exercice d'une revue sur comptes fictifs; événements d'accès/refus/administration utiles sans santé ni secrets; alerte sentinelle reçue et attribuée; procédure de mise à jour des tests et des dépendances. Preuve : export expurgé de revue, alerte et instruction opératoire. Les seuils et durées sont documentés et reliés aux choix validés, pas présentés comme des exigences légales universelles.

D-17 — Réévaluer l'AIPD et préparer la décision de pilote

E2; P1; 3,25 JP; pilote PO pour le dossier, décision du responsable compétent; avis DPO/RSSI. Dépendances : D-06/D-07/D-09/D-12/D-15/D-16/D-18 et leurs antécédents. Origine : A.3, RR-01 à RR-09, MSG-01.

User story : en tant que responsable du traitement, je veux une décision de pilote fondée sur les preuves et les limites réellement restantes.

Abuser story : en tant que décideur pressé, je transforme des tests verts ou un ticket documentaire fermé en autorisation générale de collecter la santé.

Acceptation : chaque RR relié à une preuve, un statut, un rôle et une échéance; AIPD actualisée sans reprendre les cibles conditionnelles comme des mesures; avis requis et éventuels désaccords conservés; contrats/garanties et environnement vérifiés pour les usages retenus; décision explicite de pilote restreint ou de maintien fermé. Si consultation article 36 nécessaire, elle précède l'ouverture. Preuve : dossier décisionnel, dont une conclusion de refus est recevable. La fin du sprint n'impose aucune acceptation et n'autorise pas l'export assureur.

Couverture des risques et dépendances externes

Source ouverte de C.3/revue	Tickets opérationnels, hors simple décision finale D-17
RR-01 — santé/information	SAFE-01, D-02, D-06, D-07, D-12
RR-02 — habilitations	D-01, D-03, D-08, D-09, D-18
RR-03 — assureur	SAFE-01, D-01, D-02, D-12; suspension maintenue, pas de réouverture prévue
RR-04 — historique	D-05, avec préservation décidée en INC-01
RR-05 — stockage/reprise	D-04, D-10, D-14, D-15
RR-06 — conservation/effacement	D-04, D-10, D-13, D-14, D-15
RR-07 — surface web	SAFE-01, D-11, D-18
RR-08 — usages marketing/tiers	D-07, D-12, D-18; activation non incluse
RR-09 — incident	INC-01 immédiatement; D-16 ensuite
MSG-01 — règle de messagerie	D-03 puis D-09

Dépendances extérieures à rendre visibles dans le tableau projet : disponibilité du responsable/client et des signataires; décisions de finalité/données; preuves d'hébergement et d'accès; signatures et garanties requises; éléments d'incident; avis et consultation éventuelle. Une charge de rédaction peut être consommée sans qu'une dépendance extérieure soit levée. Ces attentes ont un propriétaire, une date d'escalade et un effet sur le jalon; elles ne sont pas supposées durer zéro jour.

Hors engagement de ces trois sprints : réouverture de l'assureur, campagne réelle, transfert effectif à de nouveaux tiers, suivi sportif non implémenté, certification ou changement d'architecture non prévu. Toute demande est requalifiée, estimée et arbitrée; la réserver pour « plus tard » ne vaut pas acceptation du risque.

Annexe 3 — Données de planification

Proposition pédagogique : aucun ticket exécuté, aucune équipe mobilisée, aucun budget engagé

Valeurs issues de `planning.json`, présentées en tableaux pour la lecture. Les hypothèses et limites de D restent applicables.

Disponibilités et taux hypothétiques

DEV

Personnes : 2 Brut / événements / réserve / net (JP) : 20 / 2 / 2 / 16 Taux €/JP : 600

QA

Personnes : 1 Brut / événements / réserve / net (JP) : 6 / 1 / 1 / 4 Taux €/JP : 500

OPS

Personnes : 1 Brut / événements / réserve / net (JP) : 6 / 1 / 1 / 4 Taux €/JP : 650

PO

Personnes : 1 Brut / événements / réserve / net (JP) : 3 / 0.75 / 0.25 / 2 Taux €/JP : 650

DPO

Personnes : 1 Brut / événements / réserve / net (JP) : 3 / 0.5 / 0.5 / 2 Taux €/JP : 800

RSSI

Personnes : 1 Brut / événements / réserve / net (JP) : 3 / 0.5 / 0.5 / 2 Taux €/JP : 800

SM

Personnes : 1 Brut / événements / réserve / net (JP) : 2 / 2 / 0 / 0 Taux €/JP : 650

Charges par ticket

Ticket / phase	DEV / QA / OPS / PO / DPO / RSSI (JP)	Total JP
INC-01 / I	0.5 / 0 / 0.5 / 0.25 / 0.5 / 0.75	2.5
SAFE-01 / I	1 / 0.5 / 0.5 / 0.25 / 0 / 0.25	2.5
D-01 / S1	1 / 0.5 / 0 / 0.25 / 0 / 0.25	2.0
D-02 / S1	0.5 / 0 / 0 / 0.5 / 1 / 0.25	2.25
D-03 / S1	1 / 0.25 / 0.5 / 0.5 / 0.25 / 0.5	3.0
D-04 / S1	2 / 0.25 / 1 / 0.25 / 0 / 0.25	3.75
D-05 / S1	3 / 1 / 1 / 0.25 / 0.25 / 0.25	5.75
D-10 / S1	0.5 / 0.25 / 0.5 / 0.25 / 0.5 / 0.25	2.25
D-11 / S1	4 / 1 / 0.5 / 0 / 0 / 0.25	5.75
D-06 / S2	4 / 1.25 / 0 / 0.5 / 0.5 / 0.25	6.5
D-07 / S2	2 / 0.75 / 0 / 0.5 / 0.5 / 0	3.75
D-08 / S2	4 / 1 / 0.5 / 0.25 / 0 / 0.5	6.25
D-09 / S2	2 / 0.5 / 0 / 0.25 / 0 / 0.25	3.0
D-12 / S2	0.5 / 0 / 0.5 / 0.5 / 1 / 0.5	3.0
D-13 / S2	3 / 0.5 / 0.5 / 0 / 0 / 0.25	4.25
D-14 / S3	6 / 1.5 / 1.5 / 0.25 / 0 / 0.5	9.75
D-15 / S3	2 / 1 / 1 / 0.25 / 0.5 / 0.5	5.25
D-16 / S3	1 / 0.5 / 0.5 / 0.25 / 0.5 / 0.25	3.0

Ticket / phase	DEV / QA / OPS / PO / DPO / RSSI (JP)	Total JP
D-18 / S3	2 / 0.5 / 0.75 / 0.25 / 0.25 / 0.25	4.0
D-17 / S3	0.5 / 0.5 / 0.25 / 0.75 / 0.75 / 0.5	3.25

Priorité, dépendances et confiance

INC-01

Priorité / risque / valeur : P0 / 4 / 3 **Dépendances :** Aucune **Confiance :** faible

SAFE-01

Priorité / risque / valeur : P0 / 4 / 3 **Dépendances :** Aucune **Confiance :** moyenne

D-01

Priorité / risque / valeur : P1 / 3 / 3 **Dépendances :** SAFE-01 **Confiance :** élevée

D-02

Priorité / risque / valeur : P1 / 4 / 3 **Dépendances :** Aucune **Confiance :** faible

D-03

Priorité / risque / valeur : P1 / 4 / 3 **Dépendances :** D-02 **Confiance :** moyenne

D-04

Priorité / risque / valeur : P2 / 3 / 2 **Dépendances :** Aucune **Confiance :** faible

D-05

Priorité / risque / valeur : P1 / 4 / 2 **Dépendances :** INC-01 **Confiance :** faible

D-10

Priorité / risque / valeur : P1 / 3 / 3 **Dépendances :** D-02 **Confiance :** faible

D-11

Priorité / risque / valeur : P1 / 3 / 3 **Dépendances :** D-01 **Confiance :** moyenne

D-06

Priorité / risque / valeur : P1 / 4 / 3 **Dépendances :** D-02 **Confiance :** faible

D-07

Priorité / risque / valeur : P1 / 4 / 3 **Dépendances :** D-02 **Confiance :** moyenne

D-08

Priorité / risque / valeur : P1 / 4 / 3 **Dépendances :** D-03, D-01 **Confiance :** moyenne

D-09

Priorité / risque / valeur : P1 / 3 / 2 **Dépendances :** D-03, D-08 **Confiance :** moyenne

D-12

Priorité / risque / valeur : P1 / 4 / 3 **Dépendances :** D-02, D-04 **Confiance :** faible

D-13

Priorité / risque / valeur : P1 / 3 / 3 **Dépendances :** D-10, D-01 **Confiance :** moyenne

D-14

Priorité / risque / valeur : P2 / 3 / 3 **Dépendances :** D-04, D-08, D-13 **Confiance :** faible

D-15**Priorité / risque / valeur** : P2 / 3 / 3 **Dépendances** : D-14, D-13, D-10 **Confiance** : faible**D-16****Priorité / risque / valeur** : P2 / 3 / 2 **Dépendances** : INC-01, D-05 **Confiance** : moyenne**D-18****Priorité / risque / valeur** : P2 / 2 / 2 **Dépendances** : D-08, D-11 **Confiance** : moyenne**D-17****Priorité / risque / valeur** : P1 / 4 / 3 **Dépendances** : D-06, D-07, D-09, D-12, D-15, D-16, D-18 **Confiance** : faible

Hypothèses complémentaires

Une journée-personne représente 7 heures; une période compte 10 jours ouvrés. Indice : $(2 * \text{risk} + \text{value}) / \text{total_effort_jp}$; uniquement au sein d'une même priorité après dépendances et urgences Coordination immédiate : 0.25 JP SM. Provision d'environnement : 1500 €. Disponibilité brute réservée pour trois sprints, plus mobilisation immédiate et provision environnement; événements et réserves déjà inclus; taux hypothétiques, non devis.

Exclusions budgétaires

- Coûts passés A à C
- Incident réel au-delà de la mobilisation initiale
- Contentieux et certification
- Prestations spécialisées supplémentaires
- Temps interne des clients et signataires
- Exploitation après S3
- TVA

Conditions extérieures au lancement

- Responsables et finalités identifiés; conditions articles 6 et 9 établies pour les usages retenus, ou fonctionnalité exclue
- Accords et signatures requis obtenus; leur rédaction en D-12 ne suffit pas
- Hébergement, pays, accès et garanties documentés
- Habilitations et retraits opérables; santé individuelle exclue des accès RH
- Conservation, droits, migrations et restauration vérifiés
- Signalement traité selon les faits et B.3, sans attendre S3
- Avis pertinents et décision du responsable compétent; consultation article 36 si nécessaire
- Export assureur suspendu; campagnes et nouveaux transferts non activés

Après la troisième période

Contrôler le maintien des mesures et réestimer les écarts; aucune charge supplémentaire fictivement planifiée ou incluse dans les trois sprints.

Annexe 4 — Sources et contrôles de D

Version 1.0 — 1er octobre 2026. Cette annexe distingue ce qui vient du projet, des sources officielles consultées et de la proposition de planification. Elle complète la transparence IA; elle ne remplace pas l'annexe finale exigée par l'énoncé.

1. Ce qui provient du dépôt

Instantané de référence : 1a80376bf249dabdbbc8782388fd8d94bfcafe4fe, avant ajout de D.

Source immuable	Utilisation dans D
Énoncé, partie D, page 2	Backlog/epics/stories/abuser stories, estimations, sprints, DoD, rôles, cérémonies, indicateurs et risques du projet
Plan C.1	Horizons immédiat, court terme et structurel; maintien de la suspension et conditions de passage
Correctifs C.2	Acquis à maintenir, sans les reprogrammer comme des corrections neuves
Risques résiduels C.3	Couverture complète de RR-01 à RR-09 et maintien des limites de production
Synthèse de revue	MSG-01; distinction correction technique/décision organisationnelle
A.2, A.3 et B.3	Acteurs sous hypothèses, nécessité d'une décision santé, AIPD et traitement de l'incident

Les contrats, l'hébergement, les données d'incident et les validations manquants ne sont pas complétés par invention. Les données fictives ne servent pas à dimensionner une production réelle.

2. Recherche externe — sources primaires

Sources consultées le 1er octobre 2026. Les liens ci-dessous justifient la méthode et les limites de responsabilité, **pas les durées ou coûts choisis**.

S1 — Scrum Guide, édition novembre 2020

Ken Schwaber et Jeff Sutherland, [version HTML officielle](#). Sections utilisées : Scrum Team, Product Owner, Developers, Scrum Events, Product Backlog et Sprint Backlog. Appui sur les responsabilités, l'inspection/adaptation et l'objectif de sprint. Les trois sprints, l'équipe, les JP, l'indice de priorité et les limites de travail en cours sont des choix propres au dossier, non des obligations du guide. Le guide ne fournit pas une vélocité de WellWork.

S2 — CNIL, rôle et indépendance du DPO

[Devenir délégué à la protection des données](#) et [identifier/gérer les conflits d'intérêts](#). Fondement de la séparation entre conseil/contrôle du DPO et décision du responsable. D ne transfère pas la responsabilité de conformité au DPO et ne démontre pas que WellWork est obligée d'en désigner un.

S3 — CNIL, gestion des violations

[Notifier une violation, règles à suivre](#) et articles 33/34 dans le [chapitre IV du RGPD](#). Appui sur le traitement sans retard, les rôles et les notifications initiales/complémentaires. Le repère de planification Jp0 n'est pas le T0 de prise de connaissance de B.3; aucun calendrier agile ne remplace ces obligations.

S4 — Scrum.org, Definition of Done

[What is a Definition of Done?](#). Appui sur la DoD comme niveau commun de qualité de l'incrément, distinct des critères propres à un ticket. Les contrôles de code, de données, de preuves et de décision ajoutés dans D sont adaptés au périmètre WellWork. Un ticket documentaire terminé n'est pas présenté comme une application autorisée en production.

S5 — RGPD, AIPD et décision

[Chapitre IV, articles 24, 35, 36, 38 et 39](#). Appui sur les obligations du responsable, l'avis du DPO, la réévaluation et la consultation préalable lorsque nécessaire. Les conditions juridiques restent celles analysées en A; D organise leur traitement sans réécrire leur conclusion.

3. Hypothèses assumées

Équipe et disponibilités; journée de 7 heures; sprints de 10 jours ouvrés; efforts et indices R/V; réserves; trois sprints; coûts journaliers; provision de 1 500 €; seuils d'alerte de pilotage : **hypothèses pédagogiques proposées**, sans devis ni historique d'équipe. Les coûts ne sont pas des prix de marché vérifiés. L'objectif reste un périmètre limité sur le support existant; une contrainte nouvelle déclenche la réestimation.

Une prévision totalisant moins que la capacité ne prouve pas que toutes les validations arriveront à temps. Exemple de séquençement à discuter en S3 : D-14 en jours ouvrés 1–5; D-16 en parallèle; D-18 en jours 4–7; D-15 après D-14, en jours 6–8; D-17 en jours 9–10 après les preuves. Les présences QA/OPS/DPO doivent être réservées dans ces fenêtres, et non uniformément supposées disponibles. Ce séquençement est une hypothèse, pas un calendrier approuvé. Si D-14 glisse, D-15 puis D-17 glissent; aucun feu vert n'est conservé artificiellement.

4. Contrôles effectués sur les valeurs de planification

Un recalcul indépendant par script Python standard, dans l'environnement de travail de l'assistant, a contrôlé la matrice de préparation utilisée pour les tableaux et `planning.json`. Il ne s'agit pas d'une nouvelle exécution des tests applicatifs ni d'un workflow GitHub Actions de D.

Contrôle	Résultat calculé
Identifiants uniques et epics	20 tickets distincts; 4 epics
Dépendances	Tous les identifiants résolus; aucun cycle; aucune dépendance programmée dans un sprint ultérieur
Sources couvertes hors D-17	Chaque RR-01 à RR-09 et MSG-01 a au moins un ticket opérationnel, indépendamment de la décision finale
Décomposition de la capacité	Pour chaque rôle : brute = événements + réserve + capacité de tickets
Charges par sprint	S1 24,75; S2 26,75; S3 25,25 JP; aucune capacité nette de rôle dépassée dans le scénario nominal
Charge de tickets	76,75 JP sur les sprints + 5 JP immédiats = 81,75 JP
Capacité totale réservée	$3 \times 43 + 5 + 0,25 = 134,25$ JP, incluant facilitation et réserves
Budget de capacité par sprint	26 950 € avec les taux hypothétiques déclarés
Mobilisation initiale	$3\,325 \text{ € de tickets} + 162,50 \text{ € de coordination} = 3\,487,50 \text{ €}$
Enveloppe totale	$80\,850 + 3\,487,50 + 1\,500 = 85\,837,50 \text{ € HT}$

Les critères des fiches sont reliés aux sources et aux limites de C.3. Le scénario de sensibilité de D-08 montre volontairement un dépassement à résoudre; il ne fait pas partie des totaux nominaux. Aucune somme de CVSS ni fausse vitesse historique ne sert à calculer le budget.

Limites : ces contrôles vérifient la cohérence arithmétique et les dépendances déclarées; ils ne valident ni la productivité réelle, ni la disponibilité des signataires, ni l'architecture inconnue, ni les futures preuves de sécurité/conformité. La pagination finale A–D n'est pas mesurée ici. Les sources existantes A–C, l'application, ses tests et son workflow ne sont pas modifiés pour produire D.

5. Complément de transparence IA

Demande principale de l'étudiant : rédiger la partie D sur une branche, en insistant sur la qualité et en autorisant la recherche. L'assistant de cette conversation a utilisé la connexion GitHub pour lire les parties existantes et écrire la branche, le Web pour les sources officielles, et un script de calcul pour les charges, dépendances et coûts.

Productions : structure et texte de D, fiches de backlog, hypothèses chiffrées et contrôles. À relire personnellement par l'étudiant : caractère réaliste de l'équipe, compromis de périmètre, hypothèses de charge et budget, explication des droits des acteurs et soutenabilité des sprints. L'étudiant doit pouvoir défendre ces choix à l'oral.

Ce complément **n'atteste pas** que l'étudiant a déjà réalisé cette relecture, participé à un atelier d'estimation, obtenu des avis ou exécuté les sprints. Il n'invente pas cinq nouvelles erreurs IA; l'annexe finale doit rester fondée sur des productions réellement rencontrées et vérifiées. Les décisions métier à prendre, notamment MSG-01 et la finalité santé, sont conservées comme telles.

Annexe 5 — Preuves initiales

Document historique : les procédures et résultats ci-dessous sont conservés. La procédure actuelle de l'annexe 6 prévaut; le lanceur vérifié supprime ses fichiers temporaires, même si l'ancienne procédure mentionne AUDIT_KEEP_TEMP.

Toutes les preuves ci-dessous visent `baseline-vulnerable` (e16cedcf0f8adb359621240366c8f0cbb251b8c9). Les comptes, mots de passe sentinelles et données sont fictifs. Aucun jeton ni mot de passe n'est reproduit dans ce document.

Reproduction automatisée

Depuis `support/` :

```
node scripts/audit/reproduce-findings.js
```

Le script doit indiquer `temporaryCopy: true`, `fictionalSeed: true`, `bindAddress: 127.0.0.1`, `externalRequestsMade: false` et `projectDatabaseTouched: false`. Il supprime la copie temporaire après l'essai. Définir `AUDIT_KEEP_TEMP=1` uniquement si une inspection locale manuelle est nécessaire.

SEC-01 — injection JavaScript côté serveur

- prérequis : n'importe quel compte authentifié ;
- code : `src/routes/data.js:31-34`, puis `src/db.js:32-37` ;
- requête conceptuelle : `GET /api/users?filter=(row.auditProof='SAFE_MARKER',row.id===1)` ;
- résultat observé : HTTP 200, une ligne, propriété `auditProof` égale à `SAFE_MARKER` ;
- résultat attendu : le serveur refuse toute expression et n'accepte que des filtres déclaratifs autorisés ;
- impact : du JavaScript fourni par l'utilisateur est exécuté dans le processus serveur ;
- statut : confirmé par exécution.

La preuve modifie seulement un objet de la base fictive en mémoire. Elle ne lit aucun secret, n'exécute aucune commande et ne contacte aucun réseau externe.

PRIV-01, PRIV-02 et PRIV-03 — accès horizontal, annuaire et tenants

- prérequis : compte salarié fictif de l'entreprise `AuditTenant` ;
- requêtes : `GET /api/users/4`, puis `GET /api/users` avec le même jeton ;
- code : `src/routes/data.js:23-34` ;
- observé : profil d'un autre utilisateur et 3 questionnaires retournés; annuaire de 65 comptes et 6 valeurs d'entreprise retourné ;
- attendu : autorisation par objet, rôle et tenant, avec minimisation des champs ;
- données : identité, entreprise, date de naissance, rôle, hash de mot de passe et réponses de santé ;
- impact : accès inter-utilisateurs et inter-entreprises ;
- statut : confirmé par exécution.

Les trois constats partagent des requêtes mais couvrent des contrôles différents : propriété de l'objet, autorisation de l'annuaire et isolation B2B.

SEC-02 — élévation de rôle

- prérequis : compte salarié fictif ;
- requête : `PATCH /api/me` avec le JSON `{"role":"admin"}` ;
- code : `src/routes/accounts.js:52-58` ;
- observé : HTTP 200 et rôle `admin` dans la réponse ;
- attendu : seuls les champs de profil explicitement autorisés peuvent être modifiés ;
- impact : accès aux opérations privilégiées ;
- statut : confirmé par exécution.

PRIV-04 — export excessif

Scénario individuel RH :

- prérequis : compte RH fictif du README ;
- requête : `GET /api/exports/insurer` ;

- observé : HTTP 200 et 65 lignes couvrant toutes les entreprises.

Chaîne CHAIN-01 :

1. appliquer SEC-02 à un compte salarié ;
2. appeler GET /api/exports/insurer avec le même jeton ;
3. observer HTTP 200 et 65 lignes.

Code : src/auth.js:32-37, src/routes/data.js:48-55. Attendu : habilitation dédiée, périmètre tenant et export minimisé. La réponse locale ne prouve pas un transfert à un assureur. Statut : confirmé par exécution.

SEC-03 — session admin préchargée sans expiration

- prérequis : base temporaire nouvellement générée par db/seed.js ;
- procédure : lire la session de fixture dans la copie temporaire et l'utiliser sur GET /api/me ;
- code : db/seed.js:71-72, src/auth.js:7-21 ;
- observé : session créée le 1er mars 2024 acceptée avec HTTP 200; aucun champ d'expiration ;
- attendu : aucun jeton actif dans le seed et rejet des sessions expirées ;
- impact : accès administratif durable avec un jeton prédictible ;
- statut : confirmé par exécution.

PRIV-05 — suppression non effective

- prérequis : compte fictif ayant créé un questionnaire ;
- procédure : DELETE /api/me, GET /api/me avec l'ancien jeton, puis nouvelle connexion ;
- code : src/routes/accounts.js:37-45,62-64, src/auth.js:15-28 ;
- observé : DELETE 200, ancienne session valide, reconnexion 200, ligne utilisateur encore présente, 1 questionnaire, 2 sessions et 1 consentement restants ;
- attendu : comportement documenté de suppression/anonymisation, révocation des sessions et impossibilité de reconnexion lorsque l'effacement est annoncé ;
- statut : confirmé par exécution.

SEC-04 — mot de passe en clair dans les journaux

- prérequis : fichier de log temporaire vide ;
- procédure : tenter une connexion avec un mot de passe sentinelle fictif, puis rechercher uniquement cette sentinelle dans le log temporaire ;
- code : src/routes/accounts.js:15,39, src/logger.js:11-14 ;
- observé : sentinelle présente en clair ;
- attendu : aucun secret d'authentification dans les logs ou stdout ;
- statut : confirmé par exécution.

PRIV-06 — exposition de passwordHash

- procédures : inscription, lecture d'un profil tiers et lecture de l'annuaire ;
- code : src/routes/accounts.js:34,45,49, src/routes/data.js:27,34 ;
- observé : champ présent dans les trois types de réponse ;
- attendu : DTO de sortie excluant systématiquement les secrets dérivés ;
- statut : confirmé par exécution.

PRIV-07 — consentements imposés

- prérequis : inscription sans aucun champ de consentement ;
- code : src/routes/accounts.js:20-32 ;
- observé : marketingOptIn, consentement marketing et consentement tiers tous à true ;
- attendu : choix séparés, non pré-cochés, traçables et révocables ;
- statut : confirmé par exécution.

SEC-05 — SHA-256 sans sel

- procédure : inscrire deux comptes avec le même mot de passe fictif et comparer uniquement leurs hash ;
- code : src/db.js:25-28, db/seed.js:8-9 ;
- observé : deux chaînes hexadécimales SHA-256 identiques de 64 caractères et aucun champ de sel ;
- attendu : fonction adaptative avec sel propre à chaque hash ;

- statut : confirmé par exécution.

CODE-01 — configuration et fonction inutilisées

- recherche statique : aucun import de `src/config.js` ;
- `randomToken` : deux occurrences, définition et export dans `src/auth.js:40-44` ;
- conséquence : ni les champs de configuration ni `randomToken` ne protègent les sessions actuelles ;
- statut : constat statique.

Annexe 6 — Fiabilisation et recettes

Les mentions « non commité » et « aucun push » décrivent les recettes antérieures. Les retouches ont ensuite été publiées au commit 3d00b4b, contrôlé sur copie propre et en CI Linux/Windows : [recette du commit publié](#).

Date : 1er octobre 2026. Branche : `review/fiabilisation-audit`. Point de départ :

7fbb8f942696bf161ac5e9ead628f1aa740fa00e. Cette note complète les documents historiques sans réécrire les faits de leurs exécutions antérieures.

Ce qui change dans la procédure

Les passages anciens de B.1 et C.2 décrivant un script qui copie le répertoire courant concernent le script antérieur à cette revue. Pour l'exécution depuis la branche de revue, **la procédure ci-dessous prévaut**. Le code historique du script reste conservé byte pour byte dans `scripts/audit/historical-harness.js`; il ne doit plus être lancé directement.

La commande publique reste :

```
node scripts/audit/reproduce-findings.js
```

Le nouveau lanceur lit les objets Git du commit exact `e16cedcf0f8adb359621240366c8f0cbb251b8c9`, vérifie les empreintes de chaque fichier et construit une copie temporaire. Il refuse un historique absent, des entrées de fichiers non autorisées, un script historique modifié ou un lockfile incompatible. Il ne fait ni checkout, ni reset, ni modification de la base courante. Il réutilise les scénarios historiques existants, sans ajouter d'attaque ni contacter un système réel.

Les anciens libellés de statut ne sont plus tenus pour des preuves : les codes HTTP et les observations attendues déterminent les nouveaux statuts. Un résultat manquant ou négatif fait échouer la validation. La sortie contient le commit réellement audité, les empreintes des sources, le commit du lanceur, la présence éventuelle de changements suivis, l'environnement et les observations expurgées. Les déclarations d'isolation décrivent la procédure du script; elles ne constituent pas une capture réseau indépendante.

Le lanceur nécessite un clone Git contenant la baseline et `npm ci --ignore-scripts` avec le lockfile compatible. Les fichiers de travail sont temporaires et supprimés. Il ne remplace pas `npm test`, qui valide l'application corrigée.

Recette effectivement observée

Référence technique exécutée : `44d887928b6fde77c48f783b25e866f7bd9a48d6`.

Source : [exécution GitHub Actions 36857703645](#), jobs [Linux](#) et [Windows](#). Les deux jobs sont terminés avec succès. La sortie Linux a été relue : Node `v22.23.2`, npm `10.9.8`.

Contrôle	Résultat
Suite de tests	25 réussis, 0 échec dans la sortie Linux; étape de tests réussie également sous Windows
ESLint	Étape réussie sur les deux systèmes
Vérification CVSS	10 scores et exemples du vérificateur existant validés; ce contrôle vérifie l'arithmétique, pas la pertinence de chaque hypothèse
Baseline	12 constats dynamiques et 1 constat statique retrouvés; <code>summary.failed</code> vide dans la sortie Linux; étape réussie également sous Windows
Version réellement exécutée	Commit initial explicite et 12 fichiers source accompagnés de leurs empreintes Git
Diff et répertoire de travail	Contrôles de whitespace et d'absence de modification suivie réussis

Les sept tests ajoutés sont : trois pour l'extraction Git, deux pour la validation des observations et deux pour compléter les parcours de connexion/journalisation et la minimisation des réponses réussies. Ils ne suppriment ni ne relâchent les 18 tests antérieurs. Les fichiers applicatifs de `src/`, le seed, l'interface et le lockfile n'ont pas été modifiés par cette revue.

Les actions de CI ont uniquement une permission de lecture du contenu; aucun déploiement ni fusion n'est exécuté. Les artefacts contiennent seulement l'environnement et les résultats expurgés, conservés sept jours. Ils ne contiennent pas la base ou les journaux applicatifs. L'installation signale notamment un avertissement de support ESLint; le lockfile n'a pas été modifié pour faire disparaître cet avertissement. Aucun nouvel audit des avis de dépendances n'est revendiqué. Les ajouts documentaires ultérieurs à `44d8879` ne sont pas présentés comme réexécutés par cette recette : cette référence identifie exactement le code testé.

Index figé des sources initiales

Pour les preuves historiques, utiliser les liens ci-dessous plutôt qu'un lien relatif ouvrant le code corrigé. Les numéros restent ceux de la baseline.

Fichier initial	Lien immuable	Repères des constats
Comptes	accounts.js, lignes 11–64	SEC-02/04, PRIV-05/06/07; A.4 NC-01/04/05/07/08
Données	data.js, lignes 10–55	SEC-01, PRIV-01/02/03/04/06; questionnaires, annuaire, messages et export
Sessions	auth.js, lignes 7–44	SEC-03, PRIV-05, CODE-01
Stockage	db.js, lignes 16–53	SEC-01/05; conservation
Journaux	logger.js, lignes 6–14	SEC-04; conservation
Jeu fictif	seed.js	Données de démonstration et session historique
Interface	index.html, lignes 16–61	Parcours de collecte, A.4 NC-02/03

Reste à faire à l'assemblage : certains liens relatifs anciens dans A.3/A.4/B.1 ouvrent encore le code de la branche consultée. Cet index fournit les références correctes mais ne remplace pas automatiquement tous ces liens dans le corps des documents. Leur normalisation exhaustive n'est donc pas déclarée terminée. Conserver les ancrs de lignes précises lors de cette dernière passe.

Suivi des retouches du 1er octobre : le point ci-dessus décrit l'état de la première revue. Les 38 liens vers le code dans A.3/A.4/B.1 ont ensuite été remplacés par des liens au commit initial avec ancrs de lignes. Le test `dossier-references.test.js` vérifie les liens de A/B contre les objets Git, sans requête réseau. La pagination et les liens du PDF final restent à vérifier après export. Cette mise à jour ne modifie pas les résultats historiques de CI rapportés plus haut.

Limites conservées

Aucune base légale, durée de conservation, autorisation métier ou acceptation de risque réel n'a été inventée. Les réserves de C.3 restent ouvertes. Les observations sur données fictives ne prouvent toujours pas l'origine du fichier signalé sur le forum. Voir la [synthèse des statuts et des décisions restantes](#).

Recette locale des retouches — 1er octobre 2026

Branche locale `review/retouches-audit-partie-d`, issue de `261b27bfa2f990c6920e74bd3a10d3a3c9cf094f`, avec les retouches non commitées lors de cette recette. Environnement : Windows/PowerShell, Node v24.11.0. Ce résultat ne remplace pas la recette GitHub Actions historique et ne prétend pas à une nouvelle exécution Linux.

- **Preuve PRIV-03** : le script historique préservé peut produire un indicateur vrai lorsqu'un profil répond 403 sans propriété `company`. Le validateur exige désormais aussi les observations réussies de profil/annuaire. Trois tests supplémentaires couvrent succès, contre-exemple exact et dix cas de corroboration absente ou incohérente. Le script historique et son empreinte restent inchangés.
- **Références** : 38 liens A/B ancrés sur le commit initial; deux tests contrôlent l'absence de liens relatifs vers le code courant et la validité des fichiers/plages dans les objets Git. Les explications de B.1/C.2 distinguent maintenant l'ancien script du lanceur actuel.
- **Workflow** : pushes sur `main`, `remediation/**`, `review/**`, `docs/**` pour `support/**` ou le workflow; toutes les pull requests; déclenchement manuel déclaré. Interface, seed et dossier sont inclus. Permissions de lecture conservées, aucun déploiement. Les filtres et événements suivent la [syntaxe officielle GitHub Actions](#). Le déclenchement manuel nécessite la présence du workflow sur la branche par défaut.
- **D** : abuser story D-01 reformulée du point de vue du contributeur fautif; revalidation des références déjà corrigées, sans présenter cette correction comme future. Corps réduit de 3 658 à 3 219 mots comptés par séparation sur les espaces, soit environ 12 %. Les 20 fiches, charges, dépendances et budget sont conservés; le PDF n'a pas encore été paginé.

Contrôle local	Résultat final
Tests ciblés observations/références	7 réussites, 0 échec
<code>npm.cmd test</code>	30 réussites, 0 échec
<code>npm.cmd run lint</code>	Aucun diagnostic
Vérificateur CVSS	10 scores et contrôles internes validés
Lanceur historique	12 constats dynamiques + 1 statique, <code>summary.failed</code> vide

Contrôle local	Résultat final
Workflow	YAML parsé et filtres/permissions contrôlés localement; aucune exécution distante déclenchée

Une première exécution a détecté une fermeture de fonction manquante dans le nouveau test de références; elle a été corrigée avant les résultats finaux ci-dessus. Ce défaut du test n'a pas été attribué à l'application. Aucune modification de src/, du seed, de l'interface, du lockfile ou de la base locale n'a été nécessaire. Les quatre notes locales exclues ont été préservées; aucun push ni fusion n'a été effectué pendant ces retouches.